
NIST AI RMF 1.0

Plain-Language Subcategory and Assessment Guide

AI 100-1 Core and the Generative AI Profile (AI 600-1)

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

The seven characteristics of trustworthy AI.
All 72 subcategories of the AI RMF Core, across GOVERN, MAP, MEASURE, and MANAGE.
The twelve risks of the Generative AI Profile.

Audience

AI governance analysts, AI ethics and bias reviewers, internal auditors, and anyone assessing an AI system against the framework or training others to.

Before You Use This Document

This is a companion guide, not a copy of the standard.

The NIST AI Risk Management Framework (AI 100-1) and the Generative AI Profile (AI 600-1) are US Government works in the public domain, and unlike the ISO guides in this series there is no copyright constraint on the underlying material. This guide still describes each subcategory in original plain language rather than reproducing the framework text, because the purpose is to make the subcategories usable rather than to restate them.

Read the source publications for anything consequential, and note the framework's own framing: the AI RMF is voluntary and outcome-based. It does not prescribe how to achieve a subcategory, and it is not a compliance standard. Where an obligation is mandatory for your organization, it comes from law, regulation, or contract rather than from this framework, and this guide's suggested assessment steps are one reasonable approach rather than required procedure.

What this guide does

It takes each trustworthiness characteristic, each of the 72 subcategories, and each Generative AI Profile risk, and answers six questions about it, in the same order every time:

1. **What the subcategory asks for.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning, and the rule here is adapted to the failure mode this particular framework attracts:

Blue

Satisfied by documentation, decision records, policies, and interviews. Most of GOVERN, MAP, and MANAGE sit here.

Orange, marked CyB

Satisfied only by *empirical evidence about the system's actual behaviour*: test results, metrics, evaluation output, monitoring data, adversarial testing. Most of MEASURE sits here.

The distinction matters because the characteristic failure of AI governance is a programme that is complete in blue and empty in orange: beautifully documented governance over a model nobody ever measured. If every orange subcategory in a programme is satisfied by a policy document, that is the finding, and it is usually the most important one in the report.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers the seven characteristics of trustworthy AI, which are the properties the whole framework exists to produce. They are not subcategories and cannot be assessed directly, but nearly every finding elsewhere in the guide traces back to one of them, and reading them first makes the rest cohere.

The next four chapters cover the AI RMF Core, one subcategory per entry: GOVERN (19), MAP (18), MEASURE (22), and MANAGE (13). The final chapter covers the twelve risks of the Generative AI Profile, which is a cross-cutting overlay rather than a fifth function.

Four things worth knowing before you assess

This framework is voluntary and outcome-based. It states outcomes, not methods, so there is no single correct implementation and no certification against it. The assessment question is whether the outcome is achieved, not whether a prescribed process was followed. Be careful about writing findings that treat this guide's suggested steps as requirements.

Test the orange subcategories against evidence, not documents. A programme can satisfy every GOVERN subcategory and have never measured a model. Where a MEASURE subcategory is evidenced by a policy rather than a result, that is a finding regardless of how good the policy is.

Compare intended use against actual use, every time. Scope expansion is the most common way an assessed system becomes an unassessed one. MAP 1.1 and MAP 3.3 are where this surfaces, and it invalidates whatever assessment was performed on the narrower scope.

Report sample sizes next to every disaggregated metric. A favourable fairness result computed on a handful of cases supports no conclusion. This applies throughout MEASURE 2, and omitting sample sizes is how fairness evaluation produces the appearance of rigour without the substance.

Three definitions you need before anything else

Subcategory

The most granular level of the framework, expressed as an *outcome* rather than an action: something that is true of the organization or the system, not something it must do. This is why two organizations can satisfy the same subcategory in entirely different ways, and why a finding should describe the missing outcome rather than a missing procedure.

Explainability vs interpretability

Explainability is *how the system works*; interpretability is *what its output means* to the person receiving it. They are constantly conflated and they address different risks. An explanation of the mechanism does not tell a denied applicant what their result means, and an interpretable output does not establish the mechanism is sound.

Construct validity

Whether the thing being measured is actually the thing of interest. A model predicting re-arrest is not predicting reoffending; a model scoring interviews is not measuring job performance. This is the deepest question in any AI assessment and the one most often skipped, because when the construct is wrong, every downstream metric measures the wrong thing accurately.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The Seven Characteristics of Trustworthy AI	1
Valid and Reliable Valid and Reliable: the system does what it claims, consistently	2
Safe Safe: the system does not endanger life, health, property, or environment	3
Secure and Resilient Secure and Resilient: the system withstands adversarial and adverse events	4
Accountable and Transparent Accountable and Transparent: information is available and responsibility is assigned	5
Explainable and Interpretable Explainable and Interpretable: the mechanism and the meaning are both available	6
Privacy-Enhanced Privacy-Enhanced: norms of autonomy, identity, and dignity are safeguarded	7
Fair with Harmful Bias Managed Fair – with Harmful Bias Managed: equality and equity, with bias addressed	8
2 GOVERN: Culture, Accountability, and Oversight	9
GOVERN 1.1 Legal and regulatory requirements are understood and managed	11
GOVERN 1.2 Trustworthy AI characteristics are integrated into policy	12
GOVERN 1.3 Risk management activity is scaled to risk tolerance	13
GOVERN 1.4 The risk management process is established transparently	14
GOVERN 1.5 Monitoring and periodic review are planned with defined roles	15
GOVERN 1.6 An AI system inventory exists and is resourced	16
GOVERN 1.7 Decommissioning processes exist and are safe	17
GOVERN 2.1 Roles, responsibilities, and communication lines are documented	18
GOVERN 2.2 Personnel and partners receive AI risk management training	19
GOVERN 2.3 Executive leadership takes responsibility for AI risk decisions	20
GOVERN 3.1 Decision-making is informed by a diverse team	21
GOVERN 3.2 Human-AI configuration roles are defined and differentiated	22
GOVERN 4.1 Policies foster critical thinking and a safety-first mindset	23
GOVERN 4.2 Teams document and communicate risks and potential impacts	24
GOVERN 4.3 Practices enable testing, incident identification, and information sharing	25
GOVERN 5.1 External feedback on impacts is collected and integrated	26
GOVERN 5.2 Adjudicated feedback is incorporated into design and implementation	27
GOVERN 6.1 Third-party AI risks are addressed by policy, including IP	28
GOVERN 6.2 Contingency processes exist for third-party failures	29
3 MAP: Context, Categorization, and Impact	30
MAP 1.1 Intended purpose, context, laws, norms, and settings are documented	32
MAP 1.2 Interdisciplinary AI actors and diversity of expertise are documented	33
MAP 1.3 Organizational mission and goals for the technology are documented	34
MAP 1.4 Business value or context of use is defined or re-evaluated	35

MAP 1.5	Organizational risk tolerances are determined and documented	36
MAP 1.6	System requirements are elicited from and understood by AI actors	37
MAP 2.1	Tasks and implementation methods are defined	38
MAP 2.2	Knowledge limits and human oversight of output are documented	39
MAP 2.3	Scientific integrity and TEVV considerations are documented	40
MAP 3.1	Potential benefits are examined and documented	41
MAP 3.2	Potential costs including non-monetary costs are examined	42
MAP 3.3	Targeted application scope is specified	43
MAP 3.4	Operator and practitioner proficiency processes are defined	44
MAP 3.5	Human oversight processes are defined and assessed	45
MAP 4.1	Approaches for mapping technology and legal risks of components are in place . .	46
MAP 4.2	Internal risk controls for components are identified	47
MAP 5.1	Likelihood and magnitude of impacts are identified	48
MAP 5.2	Practices and personnel support engagement and feedback integration	49
4	MEASURE: Analysis, Testing, and Tracking	50
MEASURE 1.1	Metrics are selected, and the unmeasurable is documented	52
MEASURE 1.2	Metric appropriateness and control effectiveness are reassessed	53
MEASURE 1.3	Independent assessors and external consultation are involved	54
MEASURE 2.1	Test sets, metrics, and TEVV tooling are documented	55
MEASURE 2.2	Human subject evaluations meet requirements and are representative	56
MEASURE 2.3	Performance is measured for deployment-like conditions	57
MEASURE 2.4	Functionality and behavior are monitored in production	58
MEASURE 2.5	Validity and reliability are demonstrated, with generalizability limits	59
MEASURE 2.6	Safety risks are evaluated regularly and safe failure is demonstrated	60
MEASURE 2.7	Security and resilience are evaluated and documented	61
MEASURE 2.8	Transparency and accountability risks are examined	62
MEASURE 2.9	The model is explained, validated, and outputs interpreted in context	63
MEASURE 2.10	Privacy risk is examined and documented	64
MEASURE 2.11	Fairness and bias are evaluated and results documented	65
MEASURE 2.12	Environmental impact and sustainability are assessed	66
MEASURE 2.13	Effectiveness of TEVV metrics and processes is evaluated	67
MEASURE 3.1	Approaches to track existing, unanticipated, and emergent risks	68
MEASURE 3.2	Risk tracking where measurement is difficult or unavailable	69
MEASURE 3.3	Feedback and appeal processes for end users and impacted communities . . .	70
MEASURE 4.1	Measurement approaches are connected to deployment context	71
MEASURE 4.2	Measurement results are validated by domain experts and AI actors	72
MEASURE 4.3	Performance improvements or declines are identified from consultation and field data	73
5	MANAGE: Prioritization, Response, and Recovery	74
MANAGE 1.1	A determination is made whether to proceed	76
MANAGE 1.2	Risk treatment is prioritized	77
MANAGE 1.3	Responses to high-priority risks are developed and documented	78
MANAGE 1.4	Negative residual risks are documented	79
MANAGE 2.1	Resources and non-AI alternatives are considered	80
MANAGE 2.2	Mechanisms sustain the value of deployed systems	81
MANAGE 2.3	Procedures respond to and recover from previously unknown risks	82
MANAGE 2.4	Mechanisms to supersede, disengage, or deactivate systems	83

MANAGE 3.1	Third-party risks are monitored and controls applied	84
MANAGE 3.2	Pre-trained models are monitored as part of maintenance	85
MANAGE 4.1	Post-deployment monitoring plans are implemented	86
MANAGE 4.2	Continual improvement activities are integrated into updates	87
MANAGE 4.3	Incidents and errors are communicated and tracked	88
6	The Generative AI Profile: Twelve Risks	89
GAI: CBRN	CBRN information or capabilities	91
GAI: Confabulation	Confabulation	92
GAI: Dangerous Content	Dangerous, violent, or hateful content	93
GAI: Data Privacy	Data privacy	94
GAI: Environmental	Environmental impacts	95
GAI: Harmful Bias	Harmful bias or homogenization	96
GAI: Human-AI Configuration	Human-AI configuration	97
GAI: Information Integrity	Information integrity	98
GAI: Information Security	Information security	99
GAI: Intellectual Property	Intellectual property	100
GAI: Obscene Content	Obscene, degrading, and abusive content	101
GAI: Value Chain	Value chain and component integration	102
Glossary		103
Index of Terms and Concepts		105

The Seven Characteristics of Trustworthy AI

The seven characteristics of trustworthy AI. These are the properties the whole framework exists to produce, and they are not subcategories: you cannot assess them directly and no organization is measured against them one by one. Nearly every finding elsewhere in this guide traces back to one of them, which is why reading them first makes the rest cohere.

Two are worth holding onto as you read the functions. Valid and reliable is the foundational one, because a system that does not work cannot meaningfully be safe, fair, or secure – none of those claims survive a model that fails at its task. And validity is a claim about fitness for a specific purpose in a specific context, not a general property: strong aggregate benchmark performance says little about whether the system is valid for the population it is actually used on.

Explainable and interpretable is the pair most often conflated. Explainability concerns the mechanism, how the system works. Interpretability concerns meaning, what an output signifies to the person receiving it. They address different risks, and an explanation of the mechanism does not tell a denied applicant what their result means or what they might do about it.

Quick reference: the seven characteristics

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [CYB](#) or [AI](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Valid and Reliable	Valid and Reliable: the system does what it claims, consistently	Validation evidence tied to the stated intended use
Safe	Safe: the system does not endanger life, health, property, or environment	Safety risk analysis with severity assessment
Secure and Resilient	Secure and Resilient: the system withstands adversarial and adverse events	AI-specific threat analysis
Accountable and Transparent	Accountable and Transparent: information is available and responsibility is assigned	Named accountability assignments with authority
Explainable and Interpretable	Explainable and Interpretable: the mechanism and the meaning are both available	Explainability methods and their validation
Privacy-Enhanced	Privacy-Enhanced: norms of autonomy, identity, and dignity are safeguarded	Privacy risk assessment covering model-specific risks
Fair with Harmful Bias Managed	Fair – with Harmful Bias Managed: equality and equity, with bias addressed	Bias assessment covering systemic, computational, and human-cognitive bias

Valid and Reliable Valid and Reliable: the system does what it claims, consistently**WHAT THE SUBCATEGORY ASKS FOR**

Validity means the system has been confirmed, through objective evidence, to fulfil the requirements for its intended use. Reliability means it performs as required, without failure, for a given time interval under given conditions. The framework treats this as the foundational characteristic: a system that is not valid and reliable cannot meaningfully be safe, fair, or secure, because none of those claims survive a system that does not work. Accuracy and robustness both sit underneath this characteristic.

WHY IT EXISTS

This is the characteristic organizations most often assume rather than establish. A model with strong aggregate performance on a benchmark may be invalid for the actual deployment population, and a system reliable in testing may degrade in production as the data drifts away from what it was trained on. Validity is a claim about fitness for a specific purpose in a specific context, not a general property of the model.

HOW TO AUDIT IT

1. Establish what the system claims to do, then test whether the evidence supports that specific claim rather than a related one.
2. Check performance in conditions resembling the actual deployment setting, not only the development environment.
3. Examine whether reliability is monitored in production and whether degradation over time would be detected.
4. Look for documented limits of generalizability: where the system stops being valid.

EVIDENCE TO COLLECT

- Validation evidence tied to the stated intended use
- Performance results under deployment-like conditions
- Production monitoring for performance degradation
- Documented limits of generalizability

HOW TO DOCUMENT IT

Record the claim the system makes and the evidence offered for it, noting any gap between the population tested and the population served. Note whether degradation would be detected in production or only on complaint.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system's validity was established against a development dataset that does not represent the deployed population, and performance is not monitored in production, so the organization cannot demonstrate the system works for the people it is actually used on.

Safe Safe: the system does not endanger life, health, property, or environment

WHAT THE SUBCATEGORY ASKS FOR

The system should not, under defined conditions, lead to a state in which human life, health, property, or the environment is endangered. Safety practices include responsible design and deployment, clear information to deployers about responsible use, explicit limits on use, and the ability to fail safely and to be shut down when operating outside its knowledge limits. Safety risks posing a potential risk of serious injury or death demand the most urgent attention.

WHY IT EXISTS

Safety is proportionate to consequence, and the framework is explicit that safety considerations scale with the severity of potential harm. The characteristic that matters most in practice is the ability to fail safely: a system that degrades gracefully and can be shut down is recoverable, while one that fails silently in a high-consequence setting is not.

HOW TO AUDIT IT

1. Identify the potential safety consequences of failure and check whether the risk management effort is proportionate to them.
2. Verify the system can fail safely and can be deactivated, and test that the deactivation path actually works.
3. Check that limits on use are explicit and communicated to deployers, not merely internal.
4. Examine whether the system behaves acceptably when operated beyond its knowledge limits.

EVIDENCE TO COLLECT

- Safety risk analysis with severity assessment
- Fail-safe design and deactivation evidence
- Documented use limits communicated to deployers
- Out-of-distribution behavior testing

HOW TO DOCUMENT IT

Record whether the deactivation path has been tested rather than assumed, since an untested shutdown mechanism is the safety control most likely to fail when needed. Record how the system behaves outside its knowledge limits.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system has no tested mechanism for safe deactivation, and its behaviour beyond its knowledge limits is undocumented, so a failure in a high-consequence setting could not be reliably contained.

Secure and Resilient Secure and Resilient: the system withstands adversarial and adverse events

WHAT THE SUBCATEGORY ASKS FOR

Resilience is the ability to withstand unexpected adverse events or unexpected changes in environment and use, and to return to normal function or degrade safely. Security includes protection against attacks specific to AI systems: adversarial examples, data poisoning, model extraction, and exfiltration of model or training data. Security and resilience are related but distinct: resilience concerns returning to function, security concerns maintaining confidentiality, integrity, and availability.

WHY IT EXISTS

AI systems face attack classes that conventional security controls do not address. A perfectly patched, fire-walled system can still be defeated by poisoned training data or adversarial inputs that cause misclassification. The assessment question is whether the organization has considered AI-specific attacks at all, since most security programs cover the infrastructure and stop there.

HOW TO AUDIT IT

1. Check whether AI-specific attack classes have been considered, including data poisoning, adversarial examples, model extraction, and prompt injection where applicable.
2. Verify the training data pipeline's integrity, since poisoning enters there.
3. Examine resilience to unexpected inputs and whether the system degrades safely rather than failing unpredictably.
4. Confirm the model itself is protected as an asset against extraction and theft.

EVIDENCE TO COLLECT

- AI-specific threat analysis
- Training data integrity controls
- Adversarial robustness testing results
- Model asset protection evidence

HOW TO DOCUMENT IT

Record whether AI-specific attacks were considered distinctly from conventional infrastructure security, since a security assessment covering only the hosting environment leaves the model itself unassessed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the security assessment covered the hosting infrastructure but not AI-specific attack classes, so exposure to data poisoning, adversarial inputs, and model extraction has never been evaluated.

Accountable and Transparent Accountable and Transparent: information is available and responsibility is assigned

WHAT THE SUBCATEGORY ASKS FOR

Transparency means the extent to which information about an AI system and its outputs is available to those interacting with it, regardless of whether they know they are doing so. It spans design decisions, training data, model structure, intended use, and how and when deployment decisions were made. Accountability presupposes transparency: responsibility for the system's outcomes must be assigned to identifiable parties, and transparency is what makes that assignment meaningful.

WHY IT EXISTS

Transparency is what allows anyone outside the developing team to evaluate the system at all. Without it, risk management is self-attested. Accountability without transparency is nominal, because the accountable party cannot be held to account for decisions nobody can see. The framework notes that transparency alone does not guarantee accuracy, privacy, or fairness.

HOW TO AUDIT IT

1. Identify who is accountable for the system's outcomes by name and role, and confirm they have the authority and information to discharge it.
2. Check what information is available to those interacting with the system, including whether they know they are interacting with AI.
3. Verify design, data, and deployment decisions are documented sufficiently for external evaluation.
4. Examine whether transparency extends to affected individuals, not only to internal governance.

EVIDENCE TO COLLECT

- Named accountability assignments with authority
- System documentation available for evaluation
- Disclosure to those interacting with the system
- Deployment decision records

HOW TO DOCUMENT IT

Record who is accountable by name, and whether that person had the information to make the decisions attributed to them. Note whether affected individuals know they are subject to an AI system.

EXECUTIVE SUMMARY TREATMENT

Suggested language: accountability for the system's outcomes is not assigned to any named individual, and affected individuals are not informed that an AI system is involved in decisions about them, so neither internal nor external accountability is possible.

Explainable and Interpretable Explainable and Interpretable: the mechanism and the meaning are both available

WHAT THE SUBCATEGORY ASKS FOR

Explainability is a representation of the mechanisms underlying a system's operation: how it works. Interpretability is the meaning of the system's output in the context of its designed functional purpose: what the output means for the person receiving it. The two are distinct and address different risks, and the framework treats them together because a system can be explainable without being interpretable, and the reverse.

WHY IT EXISTS

The distinction matters in practice. An explanation of the mechanism does not tell a loan applicant what their denial means or what they might do about it, and an interpretable output does not establish that the mechanism is sound. Both are needed, calibrated to the audience: a data scientist, an operator, and an affected individual need different things from the same system.

HOW TO AUDIT IT

1. Distinguish explainability from interpretability in what the organization provides, since these are frequently conflated.
2. Check the explanation is calibrated to its audience, particularly for affected individuals rather than only technical staff.
3. Verify explanations reflect the actual model behavior rather than a simplified proxy that may mislead.
4. Examine whether operators can interpret outputs well enough to exercise the oversight assigned to them.

EVIDENCE TO COLLECT

- Explainability methods and their validation
- Interpretation guidance per audience
- Operator training on output interpretation
- Explanations provided to affected individuals

HOW TO DOCUMENT IT

Record whether explanations are validated against actual model behavior, since a post-hoc explanation that does not reflect the mechanism gives false confidence. Note whether operators can actually interpret outputs well enough to oversee the system.

EXECUTIVE SUMMARY TREATMENT

Suggested language: operators assigned oversight of the system's outputs are given no means to interpret them, so the human review relied on as a safeguard cannot function as intended.

Privacy-Enhanced Privacy-Enhanced: norms of autonomy, identity, and dignity are safeguarded

WHAT THE SUBCATEGORY ASKS FOR

Privacy refers to the norms and practices that help safeguard human autonomy, identity, and dignity, including freedom from intrusion, limiting observation, and individuals' agency to consent to disclosure of their information. Privacy values guide design choices in AI systems, and privacy-enhancing technologies such as de-identification and aggregation can support this, though they may also carry trade-offs against accuracy and fairness.

WHY IT EXISTS

AI systems create privacy risks that go beyond data protection compliance: models can memorize and reveal training data, inference can reconstruct attributes never collected, and aggregation across sources can identify individuals from data that was individually anonymous. The framework also notes the trade-off explicitly, since privacy techniques can degrade accuracy and can affect fairness for smaller groups.

HOW TO AUDIT IT

1. Check whether privacy risk was assessed for the model itself, including memorization and inference risk, not only for the data pipeline.
2. Verify de-identification holds against re-identification through inference or linkage.
3. Examine documented trade-offs where privacy techniques were applied, particularly their effect on smaller groups.
4. Confirm individuals have the agency over disclosure the framework describes.

EVIDENCE TO COLLECT

- Privacy risk assessment covering model-specific risks
- De-identification and re-identification testing
- Documented privacy and accuracy trade-offs
- Consent and agency mechanisms

HOW TO DOCUMENT IT

Record whether model-specific privacy risks were assessed distinctly from data-handling compliance, since memorization and inference risks are invisible to a conventional privacy review.

EXECUTIVE SUMMARY TREATMENT

Suggested language: privacy assessment addressed data handling but not model-specific risks, so the potential for the model to memorize and disclose training data, or to infer attributes never collected, has not been evaluated.

Fair with Harmful Bias Managed Fair – with Harmful Bias Managed: equality and equity, with bias addressed**WHAT THE SUBCATEGORY ASKS FOR**

Fairness concerns equality and equity by addressing issues such as harmful bias and discrimination. The framework identifies three categories of bias to manage: systemic bias, present in datasets, institutional norms, and practices; computational and statistical bias, arising from non-representative samples; and human-cognitive bias, in how people perceive and use system output. Notably, the framework observes that fairness standards are complex, contested, and differ across cultures and applications.

WHY IT EXISTS

The three bias categories require different responses, and organizations typically address only the computational one. Statistical parity testing does nothing about systemic bias baked into the historical data, or about the automation bias that leads an operator to defer to an output they should challenge. Because fairness definitions conflict mathematically, an organization must state which definition it is using and why.

HOW TO AUDIT IT

1. Check whether all three bias categories were considered, since most programs address only computational bias.
2. Verify the organization has stated which fairness definition it applies and why, since competing definitions cannot be satisfied simultaneously.
3. Examine bias testing across relevant subgroups, including whether subgroup sizes support reliable conclusions.
4. Look for human-cognitive bias in how operators use output, particularly automation bias in oversight roles.

EVIDENCE TO COLLECT

- Bias assessment covering systemic, computational, and human-cognitive bias
- Stated fairness definition with rationale
- Subgroup performance results with sample sizes
- Operator behavior evidence on deference to output

HOW TO DOCUMENT IT

Record which fairness definition the organization applies and whether it was chosen deliberately, since an unstated definition means fairness claims cannot be evaluated. Record subgroup sample sizes alongside results, since a fairness metric on a small subgroup may not support any conclusion.

EXECUTIVE SUMMARY TREATMENT

Suggested language: bias assessment addressed only statistical disparity in model output, with no consideration of bias in the historical data or of operator deference to system recommendations, and the organization has not stated which definition of fairness it is applying.

CHAPTER 2

GOVERN: Culture, Accountability, and Oversight

Nineteen subcategories establishing the organizational conditions everything else depends on. GOVERN is cross-cutting: it applies throughout the lifecycle rather than at a particular stage, and weaknesses here propagate into every system the organization builds or buys.

This function is almost entirely blue, assessed through documents, interviews, and decision records rather than system evidence. Three subcategories produce most of the findings. GOVERN 1.6 is the inventory, and it is assessed the same way as any asset inventory: reconcile against independent discovery, and expect the gap to be AI embedded in purchased software that nobody registered as AI. GOVERN 2.3 asks whether executive responsibility is real, and the sharpest test is whether any deployment has ever been declined. GOVERN 3.2 covers human-AI configuration, where the override rate tells you whether oversight is substantive or confirmatory.

The recurring question across this function is whether the framework has been adopted or merely referenced. GOVERN 1.2 is the direct test: trace the seven characteristics into operating procedure, and if a practitioner would never encounter them following their normal process, adoption is nominal.

Quick reference: GOVERN

Navigation: every reference and title below links to its full entry. Links shown in orange with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are blue.

Ref	Title	Primary evidence
GOVERN 1.1	Legal and regulatory requirements are understood and managed	Legal and regulatory requirement analysis with jurisdictions
GOVERN 1.2	Trustworthy AI characteristics are integrated into policy	Operating policies and procedures showing integration
GOVERN 1.3	Risk management activity is scaled to risk tolerance	Documented risk tolerance
GOVERN 1.4	The risk management process is established transparently	Documented risk management process
GOVERN 1.5	Monitoring and periodic review are planned with defined roles	Review plan with defined frequency
GOVERN 1.6	An AI system inventory exists and is resourced	AI system inventory with attributes
GOVERN 1.7	Decommissioning processes exist and are safe	Decommissioning procedures
GOVERN 2.1	Roles, responsibilities, and communication lines are documented	Documented roles and responsibilities
GOVERN 2.2	Personnel and partners receive AI risk management training	Training content mapped to roles
GOVERN 2.3	Executive leadership takes responsibility for AI risk decisions	Deployment decision records with decision-maker
GOVERN 3.1	Decision-making is informed by a diverse team	Participant records for AI risk decisions

Ref	Title	Primary evidence
GOVERN 3.2 cyb	Human-AI configuration roles are defined and differentiated	Human-AI configuration definitions per system
GOVERN 4.1	Policies foster critical thinking and a safety-first mindset	Practices supporting challenge and dissent
GOVERN 4.2	Teams document and communicate risks and potential impacts	Team-level risk and impact documentation
GOVERN 4.3 cyb	Practices enable testing, incident identification, and information sharing	Testing enablement evidence
GOVERN 5.1	External feedback on impacts is collected and integrated	External feedback mechanisms
GOVERN 5.2	Adjudicated feedback is incorporated into design and implementation	Feedback adjudication records
GOVERN 6.1	Third-party AI risks are addressed by policy, including IP	Third-party AI policies and procedures
GOVERN 6.2	Contingency processes exist for third-party failures	Third-party dependency identification

GOVERN 1.1 Legal and regulatory requirements are understood and managed**WHAT THE SUBCATEGORY ASKS FOR**

Legal and regulatory requirements involving AI are understood, managed, and documented. This covers the full applicable landscape: sector regulation, anti-discrimination law, privacy law, consumer protection, and any AI-specific regime that applies to the organization's context and jurisdictions.

WHY IT EXISTS

AI sits at the intersection of several bodies of law that were not written for it, and obligations arrive from directions organizations do not expect. A hiring model is subject to employment discrimination law, a credit model to fair lending law, and both to privacy law, regardless of whether any AI-specific regulation applies.

HOW TO AUDIT IT

1. Obtain the documented legal and regulatory analysis and check it covers sector-specific law, not only privacy and AI-specific regimes.
2. Verify the analysis is current, since this area changes rapidly.
3. Check that identified requirements are actually managed, with named owners, rather than only listed.
4. Test the analysis against one system to confirm the obligations identified are the ones that actually apply.

EVIDENCE TO COLLECT

- Legal and regulatory requirement analysis with jurisdictions
- Currency evidence and review dates
- Requirement ownership assignments

HOW TO DOCUMENT IT

Record whether the analysis covers sector-specific law beyond privacy, since the discrimination and consumer protection exposures are the ones most often missed. Note the last update date.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the legal analysis addresses privacy and AI-specific regulation but omits the sector-specific discrimination law that governs the organization's highest-impact use case.

GOVERN 1.2 Trustworthy AI characteristics are integrated into policy

WHAT THE SUBCATEGORY ASKS FOR

The characteristics of trustworthy AI are integrated into organizational policies, processes, procedures, and practices. This is the requirement that the seven characteristics stop being an external reference and become part of how the organization actually operates.

WHY IT EXISTS

A framework adopted in principle but absent from operating procedure changes nothing. This subcategory is what distinguishes organizations that reference the AI RMF from those that use it, and the test is whether a practitioner following normal procedure would encounter the characteristics without consulting the framework.

HOW TO AUDIT IT

1. Trace the seven characteristics into actual operating policies and procedures rather than a policy statement referencing them.
2. Test with a practitioner: would they encounter these considerations following their normal process?
3. Check for characteristics that appear in policy but have no corresponding procedure.
4. Verify the integration covers the full lifecycle, not only pre-deployment review.

EVIDENCE TO COLLECT

- Operating policies and procedures showing integration
- Practitioner-facing process documentation
- Lifecycle coverage evidence

HOW TO DOCUMENT IT

Record which characteristics appear in operational procedure versus only in policy statements, since the gap between the two is where adoption is nominal.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the trustworthy AI characteristics appear in the organization's AI policy but not in any operational procedure, so practitioners building and deploying systems never encounter them.

GOVERN 1.3 Risk management activity is scaled to risk tolerance**WHAT THE SUBCATEGORY ASKS FOR**

Processes, procedures, and practices are in place to determine the needed level of risk management activities based on the organization's risk tolerance. Not every AI system warrants the same scrutiny, and this subcategory requires a defensible basis for deciding how much attention each receives.

WHY IT EXISTS

Uniform treatment of all AI systems fails in both directions: it over-burdens low-risk applications and under-scrutinizes high-consequence ones. A defined risk tolerance and a tiering mechanism are what let the organization concentrate effort where consequence is greatest.

HOW TO AUDIT IT

1. Obtain the risk tolerance statement and confirm it is specific enough to drive decisions rather than aspirational.
2. Verify a tiering or triage mechanism exists and is applied consistently.
3. Test the tiering against a sample of systems and check whether the assigned tier matches the actual consequence of failure.
4. Look for high-consequence systems that received light-touch treatment.

EVIDENCE TO COLLECT

- Documented risk tolerance
- System tiering or triage criteria and results
- Evidence of differentiated treatment by tier

HOW TO DOCUMENT IT

Record whether tiering decisions match the actual consequence of failure for sampled systems, since a high-consequence system assigned a low tier is the finding that matters.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risk tiering is applied inconsistently, and a system affecting benefit eligibility decisions was assigned the lowest tier, so it received minimal review despite its consequence for individuals.

GOVERN 1.4 The risk management process is established transparently**WHAT THE SUBCATEGORY ASKS FOR**

The risk management process and its outcomes are established through transparent policies, procedures, and other controls based on organizational risk priorities. Both the process and what it produces must be visible.

WHY IT EXISTS

A risk management process that is opaque cannot be evaluated, challenged, or improved. The requirement extends to outcomes, not only process: it is not enough that decisions are made through a defined process if the decisions themselves are not visible to those who need them.

HOW TO AUDIT IT

1. Verify the risk management process is documented and its outcomes recorded and accessible.
2. Check that outcomes, not only process steps, are transparent to those who need them.
3. Confirm the process reflects stated risk priorities.

EVIDENCE TO COLLECT

- Documented risk management process
- Recorded outcomes and decisions
- Accessibility evidence

HOW TO DOCUMENT IT

Record whether risk decisions and their rationale are recorded and reachable, since undocumented outcomes cannot be reviewed or built upon.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI risk decisions are made without recorded rationale, so the basis for accepting identified risks cannot be reviewed or revisited.

GOVERN 1.5 Monitoring and periodic review are planned with defined roles**WHAT THE SUBCATEGORY ASKS FOR**

Ongoing monitoring and periodic review of the risk management process and its outcomes are planned, with organizational roles and responsibilities clearly defined, including the frequency of periodic review. This is the mechanism that keeps governance current rather than fixed at adoption.

WHY IT EXISTS

AI systems and their contexts change continuously, and a risk assessment reflects a point in time. Without planned review at a defined frequency and named owners, governance decays quietly after the initial approval, which is the characteristic failure of AI governance programs.

HOW TO AUDIT IT

1. Verify review frequency is defined and that reviews actually occurred at that frequency.
2. Check roles for monitoring and review are assigned to named individuals.
3. Compare planned review against performed review across the period.
4. Examine whether reviews produced any change, since a review that never changes anything is not functioning.

EVIDENCE TO COLLECT

- Review plan with defined frequency
- Role assignments for monitoring and review
- Review records across the period with outcomes

HOW TO DOCUMENT IT

Compare planned against actual review frequency and record whether reviews produced changes, since decay after initial approval is the characteristic finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: periodic review of AI risk management has not occurred at the defined frequency, so governance decisions reflect the systems as they were at approval rather than as they now operate.

GOVERN 1.6 An AI system inventory exists and is resourced**WHAT THE SUBCATEGORY ASKS FOR**

Mechanisms are in place to inventory AI systems and are resourced according to organizational risk priorities. The inventory is the foundation for every other governance activity, since a system absent from it receives none of them.

WHY IT EXISTS

You cannot govern what you do not know you have, and AI enters organizations through paths that bypass procurement: embedded features in purchased software, models built by business units, and services adopted by individual teams. An inventory built only from formal AI projects will miss most of the estate.

HOW TO AUDIT IT

1. Obtain the inventory and reconcile it against independent discovery, including procurement records, vendor features, and business unit activity.
2. Look specifically for AI embedded in purchased software and services, which formal inventories routinely miss.
3. Check the inventory carries enough information for governance: owner, purpose, risk tier, data used.
4. Verify the inventory is resourced and maintained rather than compiled once.

EVIDENCE TO COLLECT

- AI system inventory with attributes
- Independent discovery for reconciliation
- Maintenance and currency evidence

HOW TO DOCUMENT IT

Reconcile the inventory against independent sources and record systems found that are not inventoried, since these receive no governance at all. Note especially AI embedded in purchased tools.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems in operation are absent from the inventory, predominantly capabilities embedded in purchased software, so they are subject to no governance, review, or risk assessment.

GOVERN 1.7 Decommissioning processes exist and are safe

WHAT THE SUBCATEGORY ASKS FOR

Processes and procedures are in place for decommissioning and phasing out AI systems safely and in a manner that does not increase risks or decrease the organization's trustworthiness. Retirement is part of the lifecycle and carries its own risks.

WHY IT EXISTS

Decommissioning is the least considered phase and carries real exposure: dependent processes that silently lose a capability, data and models that persist after the system is retired, and users who continue relying on outputs no longer maintained. A poorly executed retirement can create more risk than continued operation.

HOW TO AUDIT IT

1. Verify decommissioning procedures exist and address dependent systems and processes.
2. Check handling of data, models, and artifacts after retirement.
3. Examine any actual decommissioning during the period and how it was executed.
4. Confirm users and downstream consumers are notified.

EVIDENCE TO COLLECT

- Decommissioning procedures
- Dependency analysis approach
- Records of any decommissioning performed

HOW TO DOCUMENT IT

Record whether decommissioning addresses dependent processes and residual data and models, since retirement typically leaves both behind.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no decommissioning procedure exists, so systems are retired without assessing dependent processes or disposing of the models and data they leave behind.

GOVERN 2.1 Roles, responsibilities, and communication lines are documented**WHAT THE SUBCATEGORY ASKS FOR**

Roles and responsibilities and lines of communication related to mapping, measuring, and managing AI risks are documented and are clear to individuals and teams throughout the organization. Clarity is tested at the individual level, not the org chart level.

WHY IT EXISTS

AI risk management spans data science, legal, privacy, security, and the business, and the gaps between those functions are where risks go unowned. Documented roles are necessary but the real test is whether individuals know what they are responsible for, since a documented assignment nobody is aware of does not produce action.

HOW TO AUDIT IT

1. Obtain documented roles and responsibilities across the AI lifecycle.
2. Test clarity by asking individuals what they are responsible for and comparing against the documentation.
3. Look for risks that fall between functions with no clear owner.
4. Verify communication lines are used, not merely defined.

EVIDENCE TO COLLECT

- Documented roles and responsibilities
- Communication line definitions
- Interview evidence on role clarity

HOW TO DOCUMENT IT

Record the gap between documented responsibility and individual awareness of it, since this is where assignments fail to produce action. Note risks with no identifiable owner.

EXECUTIVE SUMMARY TREATMENT

Suggested language: individuals assigned AI risk responsibilities are unaware of them, and bias assessment falls between the data science and legal functions with no owner, so it is performed by neither.

GOVERN 2.2 Personnel and partners receive AI risk management training

WHAT THE SUBCATEGORY ASKS FOR

The organization's personnel and partners receive AI risk management training enabling them to perform their duties consistent with related policies, procedures, and agreements. Training must be matched to the duties actually assigned.

WHY IT EXISTS

AI risk management asks people to perform tasks most have never been trained for: evaluating a model for bias, exercising meaningful oversight of an automated recommendation, or determining whether an output is reliable. Without training matched to those specific duties, the assignments produce activity rather than assurance.

HOW TO AUDIT IT

1. Verify training is delivered to those with AI risk duties and matched to what those duties require.
2. Check partners and vendors with assigned responsibilities are covered.
3. Test effect by asking someone with an oversight role how they would identify a problematic output.
4. Confirm training is refreshed as the technology and the systems change.

EVIDENCE TO COLLECT

- Training content mapped to roles
- Completion records including partners
- Refresh evidence

HOW TO DOCUMENT IT

Record whether those in oversight roles can articulate how they would identify a problem, since oversight without the competence to exercise it is the most common gap in AI governance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff assigned human oversight of AI outputs have received no training in how to identify a problematic output, so the human review relied upon as the primary safeguard cannot function.

GOVERN 2.3 Executive leadership takes responsibility for AI risk decisions

WHAT THE SUBCATEGORY ASKS FOR

Executive leadership of the organization takes responsibility for decisions about risks associated with AI system development and deployment. Accountability sits at a level with the authority to decline deployment.

WHY IT EXISTS

AI deployment decisions carry organizational consequence, and locating accountability below the level with authority to say no makes the accountability nominal. Executive ownership is what makes a decision not to deploy a real option rather than a theoretical one.

HOW TO AUDIT IT

1. Identify who makes deployment decisions and whether they hold executive authority.
2. Verify they receive the risk information needed to decide, including unresolved issues.
3. Check whether any deployment has been declined or delayed on risk grounds, since a process that has never said no may not be capable of it.

EVIDENCE TO COLLECT

- Deployment decision records with decision-maker
- Risk information provided to decision-makers
- Records of declined or delayed deployments

HOW TO DOCUMENT IT

Record whether the decision-maker received the unresolved risks, and whether any deployment has ever been declined, since both indicate whether executive responsibility is substantive.

EXECUTIVE SUMMARY TREATMENT

Suggested language: deployment decisions are made below executive level and no deployment has been declined or delayed on risk grounds, so the governance process has no demonstrated capacity to prevent a deployment.

GOVERN 3.1 Decision-making is informed by a diverse team**WHAT THE SUBCATEGORY ASKS FOR**

Decision-making related to mapping, measuring, and managing AI risks throughout the lifecycle is informed by a diverse team, spanning diversity of demographics, disciplines, experience, expertise, and backgrounds.

WHY IT EXISTS

Harms are frequently invisible to those unlike the people affected, and a homogeneous team reliably fails to anticipate impacts outside its own experience. Disciplinary diversity matters equally: a purely technical team will frame problems technically and miss the social and legal dimensions of the same system.

HOW TO AUDIT IT

1. Examine who actually participates in AI risk decisions, across both demographics and disciplines.
2. Check whether non-technical disciplines have genuine influence or advisory-only status.
3. Look for identified harms that a broader team would plausibly have caught earlier.
4. Verify participation is documented as the subcategory requires.

EVIDENCE TO COLLECT

- Participant records for AI risk decisions
- Disciplinary composition of review bodies
- Evidence of influence on outcomes

HOW TO DOCUMENT IT

Record the disciplinary composition of decision-making bodies and whether non-technical input changed any outcome, since advisory participation without influence does not meet the intent.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI risk decisions are made by an exclusively technical team, and non-technical input is advisory with no recorded instance of changing an outcome, so harms outside the technical frame are unlikely to be identified.

GOVERN 3.2 Human-AI configuration roles are defined and differentiated**WHAT THE SUBCATEGORY ASKS FOR**

Policies and procedures are in place to define and differentiate roles and responsibilities for human-AI configurations and oversight of AI systems. This governs how humans and the system share decision-making authority.

WHY IT EXISTS

Human oversight is the safeguard most frequently claimed and least frequently effective. The configuration matters: a human who must approve every output behaves differently from one who may override, and both differ from one reviewing a sample. Without defined roles, oversight defaults to rubber-stamping.

HOW TO AUDIT IT

1. Identify the human-AI configuration for each significant system: who decides, who reviews, who may override.
2. Verify the human role is defined with enough specificity to be performed.
3. Check whether overrides actually occur, since an override rate at or near zero suggests the oversight is nominal.
4. Examine whether the human has the time, information, and authority to exercise the role.

EVIDENCE TO COLLECT

- Human-AI configuration definitions per system
- Override and intervention records with rates
- Evidence of authority and time allocated to oversight

HOW TO DOCUMENT IT

Report the override rate for systems with human oversight, since a rate near zero across a large volume indicates the human is confirming rather than reviewing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: human reviewers overrode the system in a negligible proportion of a stated volume of decisions, and are allocated seconds per case, so the human oversight relied upon as a control is confirmatory rather than substantive.

GOVERN 4.1 Policies foster critical thinking and a safety-first mindset**WHAT THE SUBCATEGORY ASKS FOR**

Organizational policies and practices are in place to foster a critical thinking and safety-first mindset in the design, development, deployment, and use of AI systems, to minimize potential negative impacts. This is a culture requirement expressed through practice.

WHY IT EXISTS

Culture determines what happens when nobody is watching, and in AI development the pressure runs toward shipping. Practices that make it safe and expected to raise concerns are what convert a stated safety-first posture into behavior, and their absence means concerns are raised only by people willing to absorb the cost of raising them.

HOW TO AUDIT IT

1. Identify the specific practices that operationalize critical thinking, such as required challenge, red-teaming, or dissent mechanisms.
2. Check whether concerns raised during development are recorded and what happened to them.
3. Test whether staff believe raising a concern is safe and effective.
4. Look for evidence of a project delayed or changed because a concern was raised.

EVIDENCE TO COLLECT

- Practices supporting challenge and dissent
- Records of concerns raised and their resolution
- Evidence of changes resulting from concerns

HOW TO DOCUMENT IT

Record whether concerns raised during development are captured and resolved, since an absence of recorded concerns across a substantial period usually indicates they are not being raised rather than that none exist.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no mechanism exists for recording concerns raised during AI development, and none have been recorded across the period, so the organization has no evidence that its stated safety-first culture affects behaviour.

GOVERN 4.2 Teams document and communicate risks and potential impacts

WHAT THE SUBCATEGORY ASKS FOR

Organizational teams document the risks and potential impacts of the AI technology they design, develop, deploy, evaluate, and use, and communicate about the impacts more broadly. Documentation must reach beyond the team.

WHY IT EXISTS

Risk knowledge held only by the developing team does not inform the people who decide whether to deploy or who are affected by the result. The communication requirement is what moves that knowledge to where decisions are made, and its absence means decision-makers act on an incomplete picture.

HOW TO AUDIT IT

1. Verify teams document risks and potential impacts for their systems.
2. Check the documentation reaches decision-makers and other stakeholders rather than staying with the team.
3. Compare documented risks against those known informally to the team, since the gap is what is not being communicated.

EVIDENCE TO COLLECT

- Team-level risk and impact documentation
- Communication and escalation records
- Stakeholder distribution evidence

HOW TO DOCUMENT IT

Compare risks the team can articulate in interview against those documented and communicated, since the difference is the knowledge that never reaches decision-makers.

EXECUTIVE SUMMARY TREATMENT

Suggested language: development teams identified significant limitations that were never documented or communicated beyond the team, so deployment decisions were made without knowledge the organization already held.

GOVERN 4.3 Practices enable testing, incident identification, and information sharing

WHAT THE SUBCATEGORY ASKS FOR

Organizational practices are in place to enable AI testing, identification of incidents, and information sharing. This covers both the ability to test and the ability to recognize and share when something has gone wrong.

WHY IT EXISTS

AI incidents are frequently not recognized as incidents: a model degrading, producing biased outputs, or being misused looks like normal operation unless somebody is looking. Defining what constitutes an AI incident, and providing a route to report it, is what makes them visible.

HOW TO AUDIT IT

1. Verify AI testing is enabled with the access, data, and environments testing requires.
2. Check whether AI incidents are defined, since undefined incidents are not reported.
3. Examine the incident record and assess whether the absence of incidents reflects reality.
4. Confirm information sharing occurs internally and, where appropriate, externally.

EVIDENCE TO COLLECT

- Testing enablement evidence
- AI incident definition and reporting route
- Incident records across the period
- Information sharing evidence

HOW TO DOCUMENT IT

Record whether AI incidents are defined and how many were reported, since zero reported incidents across a substantial deployment usually indicates a recognition failure rather than flawless operation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not defined what constitutes an AI incident and has recorded none across the period, despite documented instances of degraded model performance, so incidents are occurring without being recognized as such.

GOVERN 5.1 External feedback on impacts is collected and integrated**WHAT THE SUBCATEGORY ASKS FOR**

Organizational policies and practices are in place to collect, consider, prioritize, and integrate feedback from those external to the team that developed or deployed the AI system, regarding potential individual and societal impacts related to AI risks.

WHY IT EXISTS

Those affected by a system see its impacts more clearly than those who built it. External feedback is the correction mechanism for the developing team's blind spots, and the requirement runs through to integration: collecting feedback that is never acted on produces no correction.

HOW TO AUDIT IT

1. Verify mechanisms exist for external parties to provide feedback on impacts.
2. Check feedback is actually received, since an unused channel may be inaccessible rather than unnecessary.
3. Trace feedback through to consideration, prioritization, and integration.
4. Look for feedback received and not acted upon, with the reasons.

EVIDENCE TO COLLECT

- External feedback mechanisms
- Feedback received across the period
- Records of consideration and resulting changes

HOW TO DOCUMENT IT

Trace a sample of feedback through to outcome, recording how much was acted upon, since feedback collected and filed is a common substitute for feedback integrated.

EXECUTIVE SUMMARY TREATMENT

Suggested language: external feedback on system impacts is collected but no instance has resulted in a change to a system, so the mechanism records concerns without correcting for them.

GOVERN 5.2 Adjudicated feedback is incorporated into design and implementation

WHAT THE SUBCATEGORY ASKS FOR

Mechanisms are established to enable the team that developed or deployed AI systems to regularly incorporate adjudicated feedback from relevant AI actors into system design and implementation. This is the return path from feedback to the system itself.

WHY IT EXISTS

Feedback that reaches a governance function but never reaches the development team changes nothing about the system. This subcategory requires the mechanism that closes that loop, and adjudication matters because not all feedback should be acted on: someone must decide, and that decision must be recorded.

HOW TO AUDIT IT

1. Verify a mechanism routes adjudicated feedback back to development teams.
2. Check the adjudication is recorded, including feedback declined and why.
3. Trace incorporation into actual design and implementation changes.
4. Confirm the mechanism operates regularly rather than exceptionally.

EVIDENCE TO COLLECT

- Feedback adjudication records
- Routing mechanism to development teams
- Design and implementation changes from feedback

HOW TO DOCUMENT IT

Record whether adjudicated feedback reaches development teams and produces changes, since a loop that stops at governance is not closed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: adjudicated feedback is not routed back to development teams, so the systems generating the concerns are never modified in response to them.

GOVERN 6.1 Third-party AI risks are addressed by policy, including IP**WHAT THE SUBCATEGORY ASKS FOR**

Policies and procedures are in place that address AI risks associated with third-party entities, including risks of infringement of a third party's intellectual property or other rights. Most organizations consume far more AI than they build.

WHY IT EXISTS

Third-party AI carries risks the organization cannot inspect directly: unknown training data, undisclosed limitations, and intellectual property exposure where a model was trained on material it had no right to use. The IP dimension is specifically named because it is a real and frequently overlooked liability that transfers to the user of the output.

HOW TO AUDIT IT

1. Verify policies address third-party AI risk, including models, APIs, and AI embedded in purchased software.
2. Check intellectual property risk is specifically addressed, including training data provenance and output ownership.
3. Examine what the organization actually knows about the third-party models it uses.
4. Confirm the policy is applied to acquisitions in practice.

EVIDENCE TO COLLECT

- Third-party AI policies and procedures
- IP risk analysis including training data provenance
- Third-party AI inventory with known attributes

HOW TO DOCUMENT IT

Record what the organization knows about the third-party models it relies on, particularly training data provenance, since unknown provenance is an unquantified IP and bias exposure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization relies on third-party models whose training data provenance is unknown and has performed no intellectual property risk analysis, so it cannot assess its exposure from the outputs it uses commercially.

GOVERN 6.2 Contingency processes exist for third-party failures

WHAT THE SUBCATEGORY ASKS FOR

Contingency processes are in place to handle failures or incidents in third-party data or AI systems deemed to be high-risk. When a dependency fails, the organization must have a plan that does not depend on the failed component.

WHY IT EXISTS

Third-party AI dependencies fail in ways that are outside the organization's control and often outside its visibility: a provider changes a model, deprecates an API, suffers an outage, or produces degraded output without notice. A contingency that assumes the provider will behave predictably is not a contingency.

HOW TO AUDIT IT

1. Identify high-risk third-party AI dependencies and verify contingency processes exist for each.
2. Check the contingency addresses silent degradation, not only outright unavailability.
3. Verify the contingency has been tested or at least validated as feasible.
4. Confirm the organization would detect a provider-side change to a model it depends on.

EVIDENCE TO COLLECT

- Third-party dependency identification
- Contingency processes per high-risk dependency
- Detection capability for provider-side change

HOW TO DOCUMENT IT

Record whether contingencies address silent model change and degradation rather than only outage, since an undisclosed provider-side model update is the failure mode most likely to go undetected.

EXECUTIVE SUMMARY TREATMENT

Suggested language: contingency planning for third-party AI addresses service outage only, and the organization has no means of detecting a provider changing the underlying model, so degraded output would continue in production unnoticed.

MAP: Context, Categorization, and Impact

Eighteen subcategories establishing what the system is, where it operates, and what it could affect. MAP produces the inputs MEASURE evaluates and MANAGE acts on, so a weak MAP function makes everything downstream unreliable regardless of how rigorously it is performed.

Mostly blue, since this is documentation and analysis rather than system testing. The highest-yield tests are comparisons. MAP 1.1 and MAP 3.3: compare documented intended purpose and specified scope against actual use, because scope expansion beyond the assessed purpose is the most common way an assessed system becomes an unassessed one. MAP 3.2: check whether cost analysis counted harms falling on individuals outside the organization, since analyses limited to organizational cost systematically understate the harm of systems that err against people.

MAP 2.3 deserves particular attention and is the deepest question in the function. Construct validity asks whether the thing being measured is the thing that matters: a model predicting re-arrest is not predicting reoffending, and a model scoring interviews is not measuring job performance. When the construct is wrong, no amount of downstream accuracy testing will surface it.

Quick reference: MAP

Navigation: every reference and title below links to its full entry. Links shown in orange with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are blue.

Ref	Title	Primary evidence
MAP 1.1	Intended purpose, context, laws, norms, and settings are documented	Documented intended purpose and beneficial uses
MAP 1.2	Interdisciplinary AI actors and diversity of expertise are documented	Participation records for context-setting
MAP 1.3	Organizational mission and goals for the technology are documented	Documented mission and AI goals
MAP 1.4	Business value or context of use is defined or re-evaluated	Business value definitions
MAP 1.5	Organizational risk tolerances are determined and documented	Documented risk tolerance
MAP 1.6	System requirements are elicited from and understood by AI actors	Elicited requirements including non-functional
MAP 2.1 cyb	Tasks and implementation methods are defined	Task and method definitions
MAP 2.2 cyb	Knowledge limits and human oversight of output are documented	Documented knowledge limits
MAP 2.3 cyb	Scientific integrity and TEVV considerations are documented	Construct validity analysis
MAP 3.1	Potential benefits are examined and documented	Documented benefit analysis with basis
MAP 3.2	Potential costs including non-monetary costs are examined	Cost analysis including non-monetary costs
MAP 3.3	Targeted application scope is specified	Specified application scope

Ref	Title	Primary evidence
MAP 3.4	Operator and practitioner proficiency processes are defined	Proficiency processes and assessment criteria
MAP 3.5 cvb	Human oversight processes are defined and assessed	Defined oversight processes
MAP 4.1	Approaches for mapping technology and legal risks of components are in place	Component-level risk mapping approach and results
MAP 4.2	Internal risk controls for components are identified	Component risk-to-control mapping
MAP 5.1	Likelihood and magnitude of impacts are identified	Impact analysis with likelihood and magnitude
MAP 5.2	Practices and personnel support engagement and feedback integration	Engagement practices with assigned personnel

MAP 1.1 Intended purpose, context, laws, norms, and settings are documented**WHAT THE SUBCATEGORY ASKS FOR**

Intended purposes, potentially beneficial uses, context-specific laws, norms and expectations, and prospective settings in which the AI system will be deployed are understood and documented. This is the context-setting that everything downstream depends on.

WHY IT EXISTS

Nearly every AI failure traces back to a mismatch between the context assumed during development and the context of actual deployment. Documenting the intended purpose and setting creates the reference point against which later drift, misuse, and scope expansion become visible. Without it, there is nothing to say the system has departed from.

HOW TO AUDIT IT

1. Obtain the documented intended purpose and deployment context, and check its specificity, since a vague purpose statement permits anything.
2. Compare documented intended use against actual use, looking for expansion beyond the original purpose.
3. Verify context-specific laws and norms for the deployment setting are identified.
4. Check the documented setting matches where the system is actually deployed.

EVIDENCE TO COLLECT

- Documented intended purpose and beneficial uses
- Deployment context and setting description
- Applicable laws and norms for the context
- Actual use evidence for comparison

HOW TO DOCUMENT IT

Compare documented intended use against observed actual use, since scope expansion beyond the assessed purpose is common and invalidates the assessment that was performed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system is used for purposes beyond those documented and assessed, so the risk assessment on which its deployment was approved does not cover its actual use.

MAP 1.2 Interdisciplinary AI actors and diversity of expertise are documented**WHAT THE SUBCATEGORY ASKS FOR**

Interdisciplinary AI actors, competencies, skills, and capacities for establishing context reflect demographic diversity and broad domain and user experience expertise, and their participation is documented. Context-setting requires people who understand the domain, not only the technology.

WHY IT EXISTS

Establishing context is the step where domain knowledge matters most, and a team without it will document a context that sounds plausible and is wrong. Domain and user experience expertise is what catches the assumptions that a technical team does not know it is making.

HOW TO AUDIT IT

1. Verify who participated in establishing context and whether domain and user experience expertise was present.
2. Check participation is documented as the subcategory requires.
3. Look for context assumptions that domain expertise would have corrected.

EVIDENCE TO COLLECT

- Participation records for context-setting
- Competency and expertise mapping
- Domain expert involvement evidence

HOW TO DOCUMENT IT

Record whether domain and user experience expertise participated in context-setting, since its absence produces plausible but incorrect context.

EXECUTIVE SUMMARY TREATMENT

Suggested language: context for the system was established without domain expertise or user experience input, so the documented operating context reflects technical assumptions rather than the environment the system operates in.

MAP 1.3 Organizational mission and goals for the technology are documented**WHAT THE SUBCATEGORY ASKS FOR**

The organization's mission and relevant goals for AI technology are understood and documented. The system's purpose must connect to something the organization is actually trying to achieve.

WHY IT EXISTS

AI adopted without a clear connection to mission tends to be adopted because it is available rather than because it is needed, which produces systems that carry risk without corresponding benefit. Documenting the mission link is what makes the benefit side of the risk calculation real.

HOW TO AUDIT IT

1. Verify the organizational mission and AI goals are documented.
2. Check individual systems connect to a stated goal rather than existing without one.
3. Look for systems deployed without an articulable mission benefit.

EVIDENCE TO COLLECT

- Documented mission and AI goals
- System-to-goal mapping

HOW TO DOCUMENT IT

Record whether each system connects to a stated organizational goal, since systems without one carry risk against no defined benefit.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of AI systems in operation have no documented connection to an organizational goal, so they carry risk without an articulated benefit to weigh it against.

MAP 1.4 Business value or context of use is defined or re-evaluated**WHAT THE SUBCATEGORY ASKS FOR**

The business value or context of business use has been clearly defined or, in the case of assessing existing AI systems, re-evaluated. For systems already in production, this is explicitly a re-evaluation rather than a retrospective justification.

WHY IT EXISTS

The re-evaluation requirement for existing systems matters because value assumed at adoption frequently fails to materialize, while the risks persist. A system that has not delivered its expected value should be reconsidered rather than continued on the strength of the original business case.

HOW TO AUDIT IT

1. Verify business value is defined for new systems and re-evaluated for existing ones.
2. Compare realized value against the value originally claimed.
3. Check whether any system has been reconsidered because value did not materialize.

EVIDENCE TO COLLECT

- Business value definitions
- Re-evaluation records for existing systems
- Realized versus expected value comparison

HOW TO DOCUMENT IT

Record whether existing systems have been re-evaluated and whether realized value matches the original case, since unrealized value alongside persistent risk is a decision the organization should be making consciously.

EXECUTIVE SUMMARY TREATMENT

Suggested language: existing AI systems have never been re-evaluated against their original business case, so systems that have not delivered their expected value continue to carry their risks unexamined.

MAP 1.5 Organizational risk tolerances are determined and documented**WHAT THE SUBCATEGORY ASKS FOR**

Organizational risk tolerances are determined and documented. Tolerance is the level of risk the organization is willing to accept, expressed specifically enough to guide decisions.

WHY IT EXISTS

Risk tolerance is what turns risk assessment into risk decision. Without a stated tolerance, every identified risk is evaluated ad hoc against whatever the decision-maker feels at the time, which produces inconsistent outcomes and makes the acceptance of a serious risk indistinguishable from the acceptance of a trivial one.

HOW TO AUDIT IT

1. Obtain the documented risk tolerance and assess whether it is specific enough to drive a decision.
2. Check tolerance is actually referenced in risk acceptance decisions.
3. Look for accepted risks that exceed the stated tolerance.

EVIDENCE TO COLLECT

- Documented risk tolerance
- Risk acceptance decisions referencing tolerance

HOW TO DOCUMENT IT

Record whether stated tolerance is specific and whether accepted risks fall within it, since risks accepted above tolerance indicate the tolerance is not functioning as a constraint.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risk tolerance is stated only in general terms and is not referenced in risk acceptance decisions, so acceptance rests on individual judgment rather than an organizational standard.

MAP 1.6 System requirements are elicited from and understood by AI actors**WHAT THE SUBCATEGORY ASKS FOR**

System requirements are elicited from and understood by relevant AI actors. Requirements including those expressing values, such as respecting user privacy, must be captured explicitly rather than assumed.

WHY IT EXISTS

Requirements not stated are not built. Value-laden requirements in particular tend to be assumed shared rather than elicited, and they are the ones most likely to be traded away under delivery pressure because nobody wrote them down as requirements in the first place.

HOW TO AUDIT IT

1. Verify requirements were elicited from relevant actors rather than assumed by the development team.
2. Check that non-functional and value-based requirements are captured explicitly.
3. Confirm the requirements are understood by those who must implement them.
4. Trace a value-based requirement through to implementation.

EVIDENCE TO COLLECT

- Elicited requirements including non-functional
- Elicitation participation records
- Traceability from requirement to implementation

HOW TO DOCUMENT IT

Trace a value-based requirement from elicitation through to implementation, since these are the requirements most likely to be dropped without a recorded decision.

EXECUTIVE SUMMARY TREATMENT

Suggested language: requirements were defined by the development team without elicitation from affected stakeholders, and stated fairness requirements have no traceable implementation, so they were dropped without a recorded decision.

MAP 2.1 Tasks and implementation methods are defined

WHAT THE SUBCATEGORY ASKS FOR

The specific tasks and the methods used to implement the tasks that the AI system will support are defined. This is the technical characterization: what the system does and how it does it.

WHY IT EXISTS

Precision here determines whether the system can be assessed at all. A system described as supporting a decision must be characterized specifically enough to know what it contributes, since the risk profile of a system that ranks options differs entirely from one that selects among them.

HOW TO AUDIT IT

1. Verify tasks and methods are defined with enough specificity to support assessment.
2. Check the described method matches the implementation.
3. Confirm the system's actual contribution to the decision is characterized accurately.

EVIDENCE TO COLLECT

- Task and method definitions
- Technical implementation documentation

HOW TO DOCUMENT IT

Record whether the documented method matches the implementation, since documentation describing a simpler method than the one deployed understates the risk.

EXECUTIVE SUMMARY TREATMENT

Suggested language: system documentation describes a simpler method than the one actually deployed, so the assessment performed does not correspond to the system in operation.

MAP 2.2 Knowledge limits and human oversight of output are documented**WHAT THE SUBCATEGORY ASKS FOR**

Information about the AI system's knowledge limits and how system output may be utilized and overseen by humans is documented. Knowledge limits define where the system stops being reliable.

WHY IT EXISTS

Every model has a boundary beyond which its outputs are unreliable, and the danger is that the system typically gives no signal when it crosses that boundary. Documenting knowledge limits, and making them available to those using the output, is what allows a user to know when not to trust it.

HOW TO AUDIT IT

1. Verify knowledge limits are documented and specific rather than generic caveats.
2. Check whether limits are communicated to those using the output.
3. Examine whether the system signals when operating near or beyond its limits.
4. Confirm oversight arrangements account for the documented limits.

EVIDENCE TO COLLECT

- Documented knowledge limits
- Communication of limits to users
- Out-of-limit signalling capability

HOW TO DOCUMENT IT

Record whether users of the output know the system's limits and whether the system signals when it exceeds them, since a confident output beyond the knowledge boundary is the most dangerous failure mode.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system's knowledge limits are documented internally but not communicated to the staff using its output, and it produces equally confident output beyond those limits, so users cannot tell when to distrust it.

MAP 2.3 Scientific integrity and TEVV considerations are documented**WHAT THE SUBCATEGORY ASKS FOR**

Scientific integrity and test, evaluation, verification, and validation considerations are identified and documented, including those related to experimental design, data collection and selection, system trustworthiness, and construct validation. Construct validity asks whether the thing measured is actually the thing intended.

WHY IT EXISTS

Construct validity is the deepest and most frequently skipped question in AI assessment: a model predicting who will be re-arrested is not predicting who will reoffend, and a model scoring interview performance is not measuring job performance. When the construct is wrong, every downstream metric measures the wrong thing accurately.

HOW TO AUDIT IT

1. Examine whether construct validity was addressed: is the measured variable actually the variable of interest?
2. Check experimental design and data selection for choices that bias the result.
3. Verify TEVV considerations were identified at design time rather than retrofitted.
4. Look for proxy variables standing in for the real construct without acknowledgement.

EVIDENCE TO COLLECT

- Construct validity analysis
- Experimental design documentation
- Data collection and selection rationale
- TEVV planning records

HOW TO DOCUMENT IT

Record what the model actually predicts versus what it is used to decide, since a proxy accepted without examination is the error that no amount of downstream accuracy testing will surface.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the model predicts a proxy variable that differs materially from the outcome decisions are based on, and this substitution was never examined, so the system's accuracy against its proxy tells the organization little about its fitness for the decision it informs.

MAP 3.1 Potential benefits are examined and documented**WHAT THE SUBCATEGORY ASKS FOR**

Potential benefits of intended AI system functionality and performance are examined and documented. Benefits must be examined rather than asserted.

WHY IT EXISTS

The benefit side of the risk-benefit calculation receives far less scrutiny than the risk side, and claimed benefits are frequently projections nobody has tested. Examining benefits is what makes the trade-off honest, since a system whose benefits are speculative should be weighed differently from one whose benefits are demonstrated.

HOW TO AUDIT IT

1. Verify benefits are documented with a basis rather than asserted.
2. Check whether claimed benefits have been validated post-deployment.
3. Compare projected against realized benefits where the system has been running.

EVIDENCE TO COLLECT

- Documented benefit analysis with basis
- Post-deployment benefit validation

HOW TO DOCUMENT IT

Record whether benefits were examined or asserted, and whether realized benefits have been checked against projections.

EXECUTIVE SUMMARY TREATMENT

Suggested language: claimed benefits were never validated after deployment, so the trade-off justifying the system's risks rests on projections that have not been tested against outcomes.

MAP 3.2 Potential costs including non-monetary costs are examined**WHAT THE SUBCATEGORY ASKS FOR**

Potential costs, including non-monetary costs, resulting from expected or realized AI errors or from system functionality and trustworthiness, are examined and documented. Non-monetary costs are named explicitly.

WHY IT EXISTS

The costs that matter most in AI are frequently not financial: a wrongly denied benefit, an unjustified investigation, or an erosion of trust in an institution. Naming non-monetary costs explicitly is what prevents a cost analysis that counts only what is easy to count and concludes the system is cheap.

HOW TO AUDIT IT

1. Verify costs are examined including non-monetary costs to individuals and communities.
2. Check the analysis considers the cost of errors, distinguishing false positives from false negatives.
3. Examine whether costs falling on people outside the organization are counted.

EVIDENCE TO COLLECT

- Cost analysis including non-monetary costs
- Error cost analysis by error type
- External cost consideration

HOW TO DOCUMENT IT

Record whether costs borne by individuals outside the organization are counted, since a cost analysis limited to organizational cost systematically understates the harm of a system that errs against people.

EXECUTIVE SUMMARY TREATMENT

Suggested language: cost analysis counted only organizational cost, omitting the consequences to individuals of erroneous decisions, so the trade-off was assessed without the harms the system principally produces.

MAP 3.3 Targeted application scope is specified

WHAT THE SUBCATEGORY ASKS FOR

Targeted application scope is specified and documented based on the system's capability, the established context, and the AI system categorization. Scope is where the system may legitimately be applied.

WHY IT EXISTS

Scope creep is the most common way an assessed system becomes an unassessed one. A model validated for one population, decision, or setting gets applied to another because it is available, and the validation does not travel with it. A specified scope is what makes the expansion visible.

HOW TO AUDIT IT

1. Obtain the specified application scope and check it is bounded and specific.
2. Compare actual application against the specified scope.
3. Verify scope is derived from demonstrated capability rather than aspiration.
4. Check whether expansion beyond scope triggers reassessment.

EVIDENCE TO COLLECT

- Specified application scope
- Actual application evidence
- Scope change and reassessment records

HOW TO DOCUMENT IT

Compare actual application against specified scope and record any expansion, noting whether it triggered reassessment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system is applied to a population outside its specified scope with no reassessment, so it is being used where its validation does not apply.

MAP 3.4 Operator and practitioner proficiency processes are defined**WHAT THE SUBCATEGORY ASKS FOR**

Processes for operator and practitioner proficiency with AI system performance and trustworthiness, and relevant technical standards and certifications, are defined, assessed, and documented. The people operating the system must be competent to do so.

WHY IT EXISTS

A system's real-world performance depends on the competence of those operating it, and proficiency is rarely assessed. An operator who does not understand the system's performance characteristics cannot recognize when it is failing, which makes them a conduit for error rather than a check on it.

HOW TO AUDIT IT

1. Verify proficiency processes exist and that proficiency is assessed rather than assumed.
2. Check operators understand the system's performance characteristics and limitations.
3. Confirm relevant standards or certifications are identified where applicable.

EVIDENCE TO COLLECT

- Proficiency processes and assessment criteria
- Operator proficiency assessment records
- Applicable standards identification

HOW TO DOCUMENT IT

Record whether operator proficiency is assessed rather than assumed, since unassessed proficiency means the reliability of the human element is unknown.

EXECUTIVE SUMMARY TREATMENT

Suggested language: operator proficiency with the system is never assessed, so the organization cannot establish that the people operating it can recognize when its output is unreliable.

MAP 3.5 Human oversight processes are defined and assessed

WHAT THE SUBCATEGORY ASKS FOR

Processes for human oversight are defined, assessed, and documented in accordance with the organizational policies established in the GOVERN function. Oversight must be defined, and then assessed to confirm it works.

WHY IT EXISTS

Human oversight is the control most commonly claimed to mitigate AI risk and the one least commonly evaluated. The assessment requirement is the substance of this subcategory: defining oversight is easy, and demonstrating that it functions as a control is where most implementations fail.

HOW TO AUDIT IT

1. Verify oversight processes are defined for each system requiring them.
2. Check oversight has been assessed for effectiveness, not merely defined.
3. Measure whether overseers have the time, information, and authority to intervene.
4. Examine intervention rates and whether interventions were correct.

EVIDENCE TO COLLECT

- Defined oversight processes
- Oversight effectiveness assessment
- Intervention rates and outcomes
- Time and information available to overseers

HOW TO DOCUMENT IT

Record whether oversight effectiveness has been assessed, and report intervention rates alongside time allocated per decision, since these together show whether oversight is substantive.

EXECUTIVE SUMMARY TREATMENT

Suggested language: human oversight is defined but its effectiveness has never been assessed, and overseers are allocated insufficient time to review the volume assigned to them, so the primary claimed mitigation is unverified.

MAP 4.1 Approaches for mapping technology and legal risks of components are in place**WHAT THE SUBCATEGORY ASKS FOR**

Approaches for mapping AI technology and legal risks of its components, including the use of third-party data or software, are in place, followed, and documented, as are risks of infringement of a third party's intellectual property or other rights.

WHY IT EXISTS

AI systems are assembled from components, and risk enters through any of them: a pre-trained model with unknown training data, a library with licensing constraints, or a dataset the organization has no right to use for this purpose. Component-level mapping is what makes these visible before they become liabilities.

HOW TO AUDIT IT

1. Verify an approach exists for mapping risks at the component level and that it is followed.
2. Check third-party data and software components are covered, including pre-trained models.
3. Examine intellectual property risk for each significant component.
4. Confirm data licensing permits the use the organization is making of it.

EVIDENCE TO COLLECT

- Component-level risk mapping approach and results
- Third-party component inventory
- IP and licensing analysis per component

HOW TO DOCUMENT IT

Record whether data licensing was examined against the actual use, since data licensed for one purpose and used for model training is a common and material exposure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: component-level risk mapping has not been performed, and data used for model training is licensed for a purpose that does not cover that use, creating unassessed legal exposure.

MAP 4.2 Internal risk controls for components are identified**WHAT THE SUBCATEGORY ASKS FOR**

Internal risk controls for components of the AI system, including third-party AI technologies, are identified and documented. Having mapped component risks, the organization must identify what controls those risks.

WHY IT EXISTS

Identifying a component risk without identifying the control leaves the risk mapped but unmitigated. This subcategory is what connects the mapping activity to actual protection, and the frequent gap is third-party components where the organization assumes the provider's controls without verifying them.

HOW TO AUDIT IT

1. Verify controls are identified for the component risks that were mapped.
2. Check controls for third-party components are real rather than assumed provider controls.
3. Look for mapped risks with no identified control.

EVIDENCE TO COLLECT

- Component risk-to-control mapping
- Third-party control verification evidence

HOW TO DOCUMENT IT

Record mapped risks with no identified control, and note where third-party controls are assumed rather than verified.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risks identified in third-party components have no corresponding controls, and the provider's controls are assumed rather than verified, so identified risks remain unmitigated.

MAP 5.1 Likelihood and magnitude of impacts are identified

WHAT THE SUBCATEGORY ASKS FOR

Likelihood and magnitude of each identified impact, both potentially beneficial and harmful, based on expected use, past uses of AI systems in similar contexts, public incident reports, feedback from those external to the developing team, or other data, are identified and documented.

WHY IT EXISTS

The subcategory names its evidence sources deliberately, and public incident reports are the most neglected: other organizations have deployed similar systems and produced documented failures, and treating each deployment as unprecedented discards evidence that is freely available.

HOW TO AUDIT IT

1. Verify impacts are identified with likelihood and magnitude rather than listed unqualified.
2. Check whether past uses in similar contexts and public incident reports informed the analysis.
3. Confirm both beneficial and harmful impacts are covered.
4. Examine whether the analysis covers impacts to groups and society, not only individuals.

EVIDENCE TO COLLECT

- Impact analysis with likelihood and magnitude
- Evidence sources including incident reports and comparable deployments
- Societal and group-level impact consideration

HOW TO DOCUMENT IT

Record whether public incident reports and comparable deployments informed the impact analysis, since ignoring available evidence of how similar systems have failed is a discrete and avoidable gap.

EXECUTIVE SUMMARY TREATMENT

Suggested language: impact analysis did not draw on documented failures of comparable systems deployed elsewhere, so known failure modes in this application area were not considered.

MAP 5.2 Practices and personnel support engagement and feedback integration**WHAT THE SUBCATEGORY ASKS FOR**

Practices and personnel for supporting regular engagement with relevant AI actors, and for integrating feedback about positive, negative, and unanticipated impacts, are in place and documented. Unanticipated impacts are named specifically.

WHY IT EXISTS

The impacts that matter most are frequently the ones nobody predicted, and they surface through engagement with those affected rather than through internal analysis. This subcategory requires the standing capacity to hear about them, staffed by named personnel, rather than an ad hoc response when something goes wrong.

HOW TO AUDIT IT

1. Verify engagement practices exist with named personnel supporting them.
2. Check the mechanism captures unanticipated impacts, not only those already on the risk register.
3. Examine what unanticipated impacts have surfaced and how they were handled.
4. Confirm engagement is regular rather than incident-driven.

EVIDENCE TO COLLECT

- Engagement practices with assigned personnel
- Records of impacts surfaced through engagement
- Integration evidence

HOW TO DOCUMENT IT

Record whether any unanticipated impact has surfaced through engagement, since a mechanism that has never produced a surprise is probably not reaching those affected.

EXECUTIVE SUMMARY TREATMENT

Suggested language: engagement with affected parties is incident-driven rather than regular and has never surfaced an unanticipated impact, so the organization has no working means of learning about harms it did not predict.

MEASURE: Analysis, Testing, and Tracking

Twenty-two subcategories, the empirical heart of the framework and the function where AI governance programs most often turn out to be hollow. This is where the guide is predominantly orange: these subcategories are satisfied by test results, metrics, and monitoring output, not by documentation.

MEASURE 2.1 through 2.13 walk the trustworthiness characteristics one at a time, and the assessment approach is consistent across them: establish what was actually tested, under what conditions, against what population, and whether the result would have detected a problem had one existed. Two structural checks apply throughout. Test against deployment conditions rather than development conditions (MEASURE 2.3, 2.5), and report subgroup sample sizes alongside any disaggregated metric (MEASURE 2.11), since a favourable fairness number computed on a handful of cases supports no conclusion at all.

Two subcategories are worth singling out. MEASURE 1.1 requires documenting what cannot be measured, and that documentation is what prevents an unmeasured risk being mistaken for an absent one; its omission is near-universal. MEASURE 2.4 asks whether production monitoring covers model behaviour rather than uptime, because a silently degrading model passes every availability check while getting steadily worse.

Quick reference: MEASURE

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
MEASURE 1.1 cyb	Metrics are selected, and the unmeasurable is documented	Selected metrics mapped to identified risks
MEASURE 1.2 cyb	Metric appropriateness and control effectiveness are re-assessed	Metric reassessment records
MEASURE 1.3	Independent assessors and external consultation are involved	Assessor independence evidence
MEASURE 2.1 cyb	Test sets, metrics, and TEVV tooling are documented	Test set documentation with composition and provenance
MEASURE 2.2 cyb	Human subject evaluations meet requirements and are representative	Human subject protection compliance evidence
MEASURE 2.3 cyb	Performance is measured for deployment-like conditions	Performance results with measurement conditions
MEASURE 2.4 cyb	Functionality and behavior are monitored in production	Production monitoring configuration and coverage
MEASURE 2.5 cyb	Validity and reliability are demonstrated, with generalizability limits	Pre-deployment validity and reliability demonstration
MEASURE 2.6 cyb	Safety risks are evaluated regularly and safe failure is demonstrated	Regular safety evaluation records
MEASURE 2.7 cyb	Security and resilience are evaluated and documented	AI-specific security evaluation results
MEASURE 2.8 cyb	Transparency and accountability risks are examined	Transparency risk analysis

Ref	Title	Primary evidence
MEASURE 2.9 CVB	The model is explained, validated, and outputs interpreted in context	Explanation methods and validation evidence
MEASURE 2.10 CVB	Privacy risk is examined and documented	Privacy risk examination covering model-specific risks
MEASURE 2.11 CVB	Fairness and bias are evaluated and results documented	Bias evaluation results by subgroup with sample sizes
MEASURE 2.12 CVB	Environmental impact and sustainability are assessed	Environmental impact assessment
MEASURE 2.13 CVB	Effectiveness of TEVV metrics and processes is evaluated	TEVV effectiveness evaluation
MEASURE 3.1 CVB	Approaches to track existing, unanticipated, and emergent risks	Risk tracking approach with assigned personnel
MEASURE 3.2	Risk tracking where measurement is difficult or unavailable	Identification of hard-to-measure risks
MEASURE 3.3 CVB	Feedback and appeal processes for end users and impacted communities	Feedback and appeal mechanisms
MEASURE 4.1	Measurement approaches are connected to deployment context	Measurement approach documentation
MEASURE 4.2 CVB	Measurement results are validated by domain experts and AI actors	Measurement results with expert review
MEASURE 4.3 CVB	Performance improvements or declines are identified from consultation and field data	Performance change tracking in both directions

MEASURE 1.1 Metrics are selected, and the unmeasurable is documented**WHAT THE SUBCATEGORY ASKS FOR**

Approaches and metrics for measurement of the AI risks enumerated during MAP are selected for implementation, starting with the most significant risks. The risks or trustworthiness characteristics that will not, or cannot, be measured are properly documented.

WHY IT EXISTS

The second half of this subcategory is the part that matters and the part routinely skipped. Documenting what cannot be measured is what prevents an unmeasured risk from being mistaken for an absent one. An organization that measures only what is easy and never states what it could not measure produces a misleading picture of its risk posture.

HOW TO AUDIT IT

1. Verify metrics were selected for the significant risks identified in MAP, and check the selection started with the most significant.
2. Obtain the documentation of risks that will not or cannot be measured, since its absence is the finding.
3. Compare the risks enumerated in MAP against those actually measured, and account for the difference.
4. Check whether unmeasured risks are treated as open rather than resolved.

EVIDENCE TO COLLECT

- Selected metrics mapped to identified risks
- Documentation of unmeasurable risks
- MAP risk register for reconciliation

HOW TO DOCUMENT IT

Reconcile risks identified in MAP against risks actually measured, and record whether the difference is documented. An undocumented gap means unmeasured risks are invisible in the risk picture.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of risks identified during mapping are not measured and the gap is undocumented, so risks that were never evaluated are indistinguishable from risks found to be absent.

MEASURE 1.2 Metric appropriateness and control effectiveness are reassessed**WHAT THE SUBCATEGORY ASKS FOR**

Appropriateness of AI metrics and effectiveness of existing controls are regularly assessed and updated, including reports of errors and potential impacts on affected communities. Metrics themselves must be evaluated, not only applied.

WHY IT EXISTS

A metric chosen at design time can become inappropriate as the system, its population, or its use changes, and a metric that no longer measures the risk gives false assurance while appearing rigorous. Reassessing the metrics is what prevents measurement from becoming ritual.

HOW TO AUDIT IT

1. Verify metrics are reassessed for continued appropriateness at a defined interval.
2. Check control effectiveness is assessed, not only control existence.
3. Examine whether error reports and community impact information feed the reassessment.
4. Look for metrics unchanged since inception despite material changes to the system.

EVIDENCE TO COLLECT

- Metric reassessment records
- Control effectiveness assessments
- Error reports and community impact input

HOW TO DOCUMENT IT

Record whether metrics have been reassessed since selection, and whether error reports informed that reassessment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: metrics have not been reassessed since the system was designed despite material changes to its user population, so current measurement may not reflect the risks now present.

MEASURE 1.3 Independent assessors and external consultation are involved

WHAT THE SUBCATEGORY ASKS FOR

Internal experts who did not serve as front-line developers, or independent assessors, are involved in regular assessments and updates. Domain experts, users, AI actors external to the developing team, and affected communities are consulted in support of assessments as necessary per organizational risk tolerance.

WHY IT EXISTS

Developers assessing their own systems find fewer problems, and not through bad faith: they share the assumptions that produced the problems. Independence is what introduces a perspective capable of questioning the design rather than only its execution.

HOW TO AUDIT IT

1. Verify assessors are independent of front-line development for the systems they assess.
2. Check whether external consultation with domain experts, users, or affected communities occurred.
3. Compare findings from independent assessment against self-assessment, since a large difference indicates the value independence adds.
4. Confirm the level of independence matches the system's risk tier.

EVIDENCE TO COLLECT

- Assessor independence evidence
- External consultation records
- Assessment findings by assessor type

HOW TO DOCUMENT IT

Record who assessed each system and their relationship to its development, since self-assessment of high-risk systems is a discrete finding regardless of the quality of the assessment produced.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's highest-risk AI systems are assessed by the teams that built them, with no independent review and no consultation with affected communities, so the assessments carry the same assumptions as the designs.

MEASURE 2.1 Test sets, metrics, and TEVV tooling are documented**WHAT THE SUBCATEGORY ASKS FOR**

Test sets, metrics, and details about the tools used during test, evaluation, verification, and validation are documented. The measurement apparatus itself must be recorded.

WHY IT EXISTS

Results are only interpretable if the conditions producing them are known. An accuracy figure without its test set is uninterpretable, and undocumented test sets prevent anyone from asking the questions that matter: whether the test data represents the deployment population, and whether it overlaps the training data.

HOW TO AUDIT IT

1. Verify test sets are documented, including composition and provenance.
2. Check for train-test contamination, since overlap inflates every reported result.
3. Confirm metrics and tooling are documented sufficiently to reproduce the evaluation.
4. Compare test set composition against the deployment population.

EVIDENCE TO COLLECT

- Test set documentation with composition and provenance
- Metric definitions and tooling details
- Train-test separation evidence

HOW TO DOCUMENT IT

Record test set composition against the deployment population, and check explicitly for train-test overlap, since contamination invalidates every performance claim downstream of it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: test set composition is undocumented and its separation from training data cannot be established, so the reported performance figures cannot be relied upon.

MEASURE 2.2 Human subject evaluations meet requirements and are representative**WHAT THE SUBCATEGORY ASKS FOR**

Evaluations involving human subjects meet applicable requirements, including human subject protection, and are representative of the relevant population. Both the ethical and the representativeness obligations apply.

WHY IT EXISTS

Evaluations involving people carry protection obligations that AI teams may not recognize as applying to them, and unrepresentative subject pools produce results that do not generalize to the deployed population. Convenience samples of internal staff are the common failure on both counts.

HOW TO AUDIT IT

1. Verify human subject protection requirements were identified and met where evaluations involved people.
2. Check subject pools are representative of the relevant population rather than convenient.
3. Confirm any required review or approval was obtained.

EVIDENCE TO COLLECT

- Human subject protection compliance evidence
- Subject pool composition against target population
- Required approvals

HOW TO DOCUMENT IT

Record subject pool composition against the deployed population, since internal staff standing in for the public produces results that do not transfer.

EXECUTIVE SUMMARY TREATMENT

Suggested language: human evaluation used internal staff as subjects rather than a representative sample of the affected population, so the results do not support conclusions about the system's performance in deployment.

MEASURE 2.3 Performance is measured for deployment-like conditions

WHAT THE SUBCATEGORY ASKS FOR

AI system performance or assurance criteria are measured qualitatively or quantitatively and demonstrated for conditions similar to the deployment setting. Measures are documented.

WHY IT EXISTS

Performance in a development environment routinely fails to transfer to deployment, where data is messier, distributions differ, and conditions vary. Measuring under deployment-like conditions is what makes performance claims meaningful, and the absence of this step is why so many systems underperform their reported figures in production.

HOW TO AUDIT IT

1. Verify performance was measured under conditions resembling deployment, not only in development.
2. Compare the conditions of measurement against actual deployment conditions.
3. Check performance is disaggregated rather than reported only in aggregate.
4. Confirm measures are documented with their conditions.

EVIDENCE TO COLLECT

- Performance results with measurement conditions
- Deployment condition description for comparison
- Disaggregated performance results

HOW TO DOCUMENT IT

Record the conditions under which performance was measured against actual deployment conditions, since the gap between them predicts the gap between reported and realized performance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: performance was demonstrated only under development conditions that differ materially from deployment, so reported accuracy does not describe how the system performs in service.

MEASURE 2.4 Functionality and behavior are monitored in production

WHAT THE SUBCATEGORY ASKS FOR

The functionality and behavior of the AI system and its components, as identified in the MAP function, are monitored when in production. Monitoring must cover the components mapped, not only overall availability.

WHY IT EXISTS

Model performance degrades in production as the world diverges from the training data, and the degradation is silent: the system continues producing confident outputs that are progressively less correct. Production monitoring of behavior, as distinct from uptime, is the only way this is detected before it causes harm.

HOW TO AUDIT IT

1. Verify production monitoring covers model behavior and output quality, not only system availability.
2. Check whether drift in input distribution or output distribution would be detected.
3. Examine alerting thresholds and whether anyone acts on them.
4. Confirm monitoring covers the components identified during MAP.

EVIDENCE TO COLLECT

- Production monitoring configuration and coverage
- Drift detection capability and results
- Alerting thresholds and response records

HOW TO DOCUMENT IT

Record whether monitoring detects behavioral degradation as distinct from availability, since uptime monitoring on a silently degrading model provides no protection at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: production monitoring covers system availability but not model behaviour, so performance degradation would continue undetected until it produced a complaint or a visible failure.

MEASURE 2.5 Validity and reliability are demonstrated, with generalizability limits

WHAT THE SUBCATEGORY ASKS FOR

The AI system to be deployed is demonstrated to be valid and reliable. Limitations of generalizability beyond the conditions under which the technology was developed are documented.

WHY IT EXISTS

This subcategory requires demonstration before deployment, not after, and pairs it with the explicit statement of where validity stops. The generalizability limits are what allow a deployment decision to be bounded, and their absence permits a system validated narrowly to be deployed broadly on the strength of that narrow validation.

HOW TO AUDIT IT

1. Verify validity and reliability were demonstrated before deployment.
2. Obtain the documented limits of generalizability and check they are specific.
3. Compare deployment scope against the conditions under which validity was demonstrated.
4. Look for deployment beyond the demonstrated conditions.

EVIDENCE TO COLLECT

- Pre-deployment validity and reliability demonstration
- Documented generalizability limits
- Deployment scope for comparison

HOW TO DOCUMENT IT

Compare the conditions under which validity was demonstrated against the conditions of actual deployment, and record any deployment outside the demonstrated envelope.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system was validated on one population and deployed to a materially different one, with no documented limits of generalizability, so its demonstrated validity does not extend to its actual use.

MEASURE 2.6 Safety risks are evaluated regularly and safe failure is demonstrated**WHAT THE SUBCATEGORY ASKS FOR**

The AI system is evaluated regularly for the safety risks identified in MAP. The system to be deployed is demonstrated to be safe, its residual negative risk does not exceed risk tolerance, and it can fail safely, particularly when made to operate beyond its knowledge limits. Safety metrics reflect reliability, robustness, real-time monitoring, and response times for failures.

WHY IT EXISTS

Safe failure beyond knowledge limits is the specific requirement worth testing, because it is where systems behave least predictably and where the failure is least likely to announce itself. Response time is included because a safety mechanism that operates too slowly does not prevent the harm.

HOW TO AUDIT IT

1. Verify safety evaluation occurs regularly against the risks identified in MAP.
2. Test behavior beyond knowledge limits and confirm failure is safe rather than confident and wrong.
3. Check residual risk against stated tolerance.
4. Measure response times for failure detection and intervention.

EVIDENCE TO COLLECT

- Regular safety evaluation records
- Out-of-limits behavior testing
- Residual risk against tolerance
- Failure response time measurements

HOW TO DOCUMENT IT

Record how the system behaves beyond its knowledge limits and how quickly a failure would be detected and acted upon, since these determine whether a safety incident is contained or completed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system produces confident output beyond its knowledge limits with no safe-failure behaviour, and failure detection depends on manual review occurring days later, so an unsafe output would be acted upon before it was identified.

MEASURE 2.7 Security and resilience are evaluated and documented

WHAT THE SUBCATEGORY ASKS FOR

AI system security and resilience, as identified in the MAP function, are evaluated and documented. This is the evaluation counterpart to the security and resilience characteristic.

WHY IT EXISTS

Security evaluation of AI systems must cover the AI-specific attack surface, which conventional security testing does not reach. Evaluating the hosting environment and declaring the system secure leaves the model, its training pipeline, and its inputs entirely unassessed.

HOW TO AUDIT IT

1. Verify security evaluation covers AI-specific attacks: adversarial inputs, poisoning, extraction, and prompt injection where relevant.
2. Check resilience testing covers unexpected inputs and adverse conditions.
3. Confirm the evaluation is documented with methods and results.
4. Compare the evaluation scope against the risks identified during MAP.

EVIDENCE TO COLLECT

- AI-specific security evaluation results
- Resilience testing under adverse conditions
- Evaluation scope against mapped risks

HOW TO DOCUMENT IT

Record whether security evaluation reached the model and its pipeline or stopped at the infrastructure, since the latter leaves the AI-specific attack surface unassessed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security evaluation covered infrastructure only, with no testing for adversarial inputs, data poisoning, or model extraction, so the AI-specific attack surface has never been assessed.

MEASURE 2.8 Transparency and accountability risks are examined**WHAT THE SUBCATEGORY ASKS FOR**

Risks associated with transparency and accountability, as identified in the MAP function, are examined and documented. Transparency itself carries risk, in both directions.

WHY IT EXISTS

Insufficient transparency prevents evaluation and accountability, while excessive disclosure can enable gaming of the system or expose proprietary and security-sensitive information. This subcategory asks the organization to reason about that trade-off deliberately rather than defaulting to one extreme.

HOW TO AUDIT IT

1. Verify transparency and accountability risks were examined in both directions.
2. Check whether the level of disclosure was a deliberate decision with recorded reasoning.
3. Examine whether accountability gaps identified during MAP were addressed.

EVIDENCE TO COLLECT

- Transparency risk analysis
- Disclosure decisions with rationale
- Accountability gap analysis

HOW TO DOCUMENT IT

Record whether disclosure levels were deliberately reasoned, since a default to minimum disclosure without analysis is a decision the organization has not actually made.

EXECUTIVE SUMMARY TREATMENT

Suggested language: disclosure about the system defaults to the minimum with no analysis of the trade-off, so the organization has not established that its transparency posture is appropriate to the system's impact.

MEASURE 2.9 The model is explained, validated, and outputs interpreted in context**WHAT THE SUBCATEGORY ASKS FOR**

The AI model is explained, validated, and documented, and AI system output is interpreted within its context, as identified in the MAP function, to inform responsible use and governance. Explanation and interpretation must both be present, and the explanation must be validated.

WHY IT EXISTS

Explanation methods can be wrong. A post-hoc explanation that does not faithfully reflect the model's actual behavior gives confident but misleading accounts of why a decision was made, which is worse than no explanation because it is trusted. Validating the explanation is what distinguishes the two.

HOW TO AUDIT IT

1. Verify explanation methods are used and that they have been validated for faithfulness to the model.
2. Check interpretation guidance exists for the deployment context.
3. Test whether explanations given for specific outputs are consistent and plausible.
4. Confirm those receiving explanations can use them.

EVIDENCE TO COLLECT

- Explanation methods and validation evidence
- Interpretation guidance for the context
- Sample explanations for specific outputs

HOW TO DOCUMENT IT

Record whether the explanation method was validated against actual model behavior, since an unvalidated explanation may be systematically misleading while appearing rigorous.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the explanation method used has never been validated for faithfulness to the model, so the explanations provided to decision-makers and affected individuals may not reflect the reasons for the outputs they describe.

MEASURE 2.10 Privacy risk is examined and documented**WHAT THE SUBCATEGORY ASKS FOR**

Privacy risk of the AI system, as identified in the MAP function, is examined and documented. This is the measurement counterpart to the privacy-enhanced characteristic.

WHY IT EXISTS

AI-specific privacy risks require specific testing: whether the model memorizes and can be induced to reveal training data, whether it infers protected attributes it was never given, and whether outputs allow re-identification. None of these are visible to a conventional privacy impact assessment.

HOW TO AUDIT IT

1. Verify privacy risk examination covers model-specific risks including memorization and inference.
2. Check testing for training data extraction where the model architecture makes it plausible.
3. Examine whether the system infers sensitive attributes it was not given.
4. Confirm re-identification risk from outputs was assessed.

EVIDENCE TO COLLECT

- Privacy risk examination covering model-specific risks
- Memorization and extraction testing results
- Attribute inference analysis

HOW TO DOCUMENT IT

Record whether memorization and inference were actually tested rather than assessed by questionnaire, since these risks are only visible through testing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: privacy assessment was conducted by questionnaire with no testing for training data memorization or sensitive attribute inference, so the model-specific privacy risks remain unmeasured.

MEASURE 2.11 Fairness and bias are evaluated and results documented**WHAT THE SUBCATEGORY ASKS FOR**

Fairness and bias, as identified in the MAP function, are evaluated and results are documented. This is where the fairness characteristic becomes an empirical result rather than an intention.

WHY IT EXISTS

Fairness evaluation is where AI governance most often produces the appearance of rigor without substance: a single parity metric on a convenient grouping, computed once, with no examination of subgroup sample sizes or of which fairness definition was chosen. The evaluation must be capable of detecting a problem if one exists.

HOW TO AUDIT IT

1. Verify bias evaluation covers the relevant protected groups and intersections, not only single attributes.
2. Check subgroup sample sizes support the conclusions drawn, since small subgroups produce unstable metrics.
3. Confirm the fairness definition used is stated and appropriate to the context.
4. Examine whether evaluation is repeated over time rather than performed once before launch.

EVIDENCE TO COLLECT

- Bias evaluation results by subgroup with sample sizes
- Stated fairness definition and rationale
- Intersectional analysis
- Repeat evaluation records

HOW TO DOCUMENT IT

Report subgroup sample sizes alongside fairness metrics, since a favourable metric computed on a handful of cases supports no conclusion. Record whether evaluation has been repeated since launch.

EXECUTIVE SUMMARY TREATMENT

Suggested language: fairness evaluation was performed once before launch on single attributes only, with subgroup sample sizes too small to support conclusions, so disparate performance affecting smaller groups would not have been detected.

MEASURE 2.12 Environmental impact and sustainability are assessed**WHAT THE SUBCATEGORY ASKS FOR**

Environmental impact and sustainability of AI model training and management activities, as identified in the MAP function, are assessed and documented. Training and operating models consumes substantial energy.

WHY IT EXISTS

The environmental cost of large model training and inference is material and, unlike most AI risks, is straightforwardly quantifiable. It is included in the framework because it is a real impact that organizations systematically fail to count, particularly for models trained repeatedly during development.

HOW TO AUDIT IT

1. Verify environmental impact of training and operation is assessed.
2. Check the assessment covers repeated training runs during development, not only the final model.
3. Confirm ongoing inference costs are included.

EVIDENCE TO COLLECT

- Environmental impact assessment
- Training and inference energy or emissions data

HOW TO DOCUMENT IT

Record whether environmental assessment covers development iterations and ongoing inference rather than a single training run.

EXECUTIVE SUMMARY TREATMENT

Suggested language: environmental impact has not been assessed for AI training or operation, so a material and quantifiable cost of the organization's AI activity is uncounted.

MEASURE 2.13 Effectiveness of TEVV metrics and processes is evaluated**WHAT THE SUBCATEGORY ASKS FOR**

Effectiveness of the employed TEVV metrics and processes in the MEASURE function is evaluated and documented. The measurement function measures itself.

WHY IT EXISTS

This is the framework's self-correction mechanism. Measurement processes can be systematically blind, and only an evaluation of the measurement itself will reveal it. The practical test is whether problems reaching production were ones the measurement process should have caught.

HOW TO AUDIT IT

1. Verify TEVV effectiveness is evaluated rather than assumed.
2. Compare problems found in production against what measurement should have detected before deployment.
3. Check whether measurement processes have been changed as a result of such comparisons.

EVIDENCE TO COLLECT

- TEVV effectiveness evaluation
- Production issues traced against pre-deployment measurement
- Measurement process changes

HOW TO DOCUMENT IT

Trace production issues back to whether measurement should have caught them, since this is the most direct evidence of measurement effectiveness available.

EXECUTIVE SUMMARY TREATMENT

Suggested language: issues identified in production were within the scope of pre-deployment testing but were not detected, and the measurement process has not been revised in response, so the same class of issue will recur.

MEASURE 3.1 Approaches to track existing, unanticipated, and emergent risks

WHAT THE SUBCATEGORY ASKS FOR

Approaches, personnel, and documentation are in place to regularly identify and track existing, unanticipated, and emergent AI risks, based on factors such as intended and actual performance in deployed contexts. Emergent risks are those that appear as the system operates.

WHY IT EXISTS

Risks identified before deployment are a subset of those that will arise. Emergent risks appear through interaction between the system, its users, and a changing environment, and only a standing tracking capability will catch them. A risk register fixed at deployment is a snapshot that ages badly.

HOW TO AUDIT IT

1. Verify a capability exists to identify risks arising after deployment, with assigned personnel.
2. Check whether the risk register has changed since deployment.
3. Examine what emergent risks have been identified and how.

EVIDENCE TO COLLECT

- Risk tracking approach with assigned personnel
- Risk register change history
- Emergent risks identified post-deployment

HOW TO DOCUMENT IT

Record whether the risk register has changed since deployment, since a static register indicates emergent risks are not being identified rather than that none have arisen.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the AI risk register has not changed since deployment, so risks emerging from actual operation are not being identified and the organization's risk picture is fixed at the point of launch.

MEASURE 3.2 Risk tracking where measurement is difficult or unavailable**WHAT THE SUBCATEGORY ASKS FOR**

Risk tracking approaches are considered for settings where AI risks are difficult to assess using currently available measurement techniques, or where metrics are not yet available. Some risks resist measurement.

WHY IT EXISTS

Some of the most serious AI risks, including societal effects and long-term impacts, have no established metrics. The framework requires that these be tracked by other means rather than dropped for being unmeasurable, which is the natural tendency of any measurement-driven process.

HOW TO AUDIT IT

1. Identify risks acknowledged as difficult to measure and check what tracking approach applies to them.
2. Verify these risks remain visible in governance rather than dropping out for lack of a metric.
3. Check qualitative or proxy approaches are used where quantitative measurement is unavailable.

EVIDENCE TO COLLECT

- Identification of hard-to-measure risks
- Alternative tracking approaches
- Visibility of these risks in governance reporting

HOW TO DOCUMENT IT

Record whether hard-to-measure risks remain visible in governance reporting, since risks without metrics tend to disappear from measurement-driven processes entirely.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risks without established metrics, including societal impact, are absent from governance reporting entirely, so the risks hardest to measure receive the least attention rather than the most.

MEASURE 3.3 Feedback and appeal processes for end users and impacted communities

WHAT THE SUBCATEGORY ASKS FOR

Feedback processes for end users and impacted communities to report problems and appeal system outcomes are established and integrated into AI system evaluation metrics. Appeal is named specifically, and the feedback must feed evaluation.

WHY IT EXISTS

Appeal is a substantive right for people subject to automated decisions, and it doubles as a detection mechanism: appeals cluster where the system is wrong. Integrating appeal data into evaluation metrics turns individual complaints into a signal about system performance.

HOW TO AUDIT IT

1. Verify feedback and appeal mechanisms exist and are accessible to those affected.
2. Check appeals reach a human with authority to change the outcome.
3. Confirm appeal and feedback data are integrated into evaluation metrics rather than handled only case by case.
4. Examine appeal volumes and outcomes for patterns indicating systematic error.

EVIDENCE TO COLLECT

- Feedback and appeal mechanisms
- Appeal volumes and outcomes
- Integration into evaluation metrics

HOW TO DOCUMENT IT

Report appeal volumes and overturn rates, and record whether this data feeds evaluation, since a high overturn rate is direct evidence of systematic error that case-by-case handling will not surface.

EXECUTIVE SUMMARY TREATMENT

Suggested language: appeals are handled case by case with a stated overturn rate, and the data is not integrated into system evaluation, so a strong signal of systematic error is being discarded.

MEASURE 4.1 Measurement approaches are connected to deployment context**WHAT THE SUBCATEGORY ASKS FOR**

Measurement approaches for identifying AI risks are connected to deployment contexts and informed through consultation with domain experts and other end users. Approaches are documented.

WHY IT EXISTS

A measurement approach designed without reference to the deployment context will measure what is convenient rather than what matters. Domain experts and end users know which failures are consequential in practice, and that knowledge is what directs measurement effort toward the risks that count.

HOW TO AUDIT IT

1. Verify measurement approaches were informed by consultation with domain experts and end users.
2. Check the approaches connect to the actual deployment context.
3. Confirm approaches are documented.

EVIDENCE TO COLLECT

- Measurement approach documentation
- Consultation records with domain experts and users
- Deployment context linkage

HOW TO DOCUMENT IT

Record whether domain experts and end users informed the measurement approach, since measurement designed in isolation tends to optimize for what is easy to compute.

EXECUTIVE SUMMARY TREATMENT

Suggested language: measurement approaches were designed without consultation with domain experts or end users, so the system is measured against convenient metrics rather than the failures that matter in its operating context.

MEASURE 4.2 Measurement results are validated by domain experts and AI actors**WHAT THE SUBCATEGORY ASKS FOR**

Measurement results regarding AI system trustworthiness in deployment contexts and across the AI lifecycle are informed by input from domain experts and relevant AI actors, to validate whether the system is performing consistently as intended. Results are documented.

WHY IT EXISTS

A metric can look acceptable while the system fails in ways the metric does not capture. Domain expert review of results is what catches the gap between a satisfactory number and unsatisfactory real-world behavior, and it is the check that prevents measurement from becoming self-confirming.

HOW TO AUDIT IT

1. Verify measurement results are reviewed by domain experts rather than only by the measuring team.
2. Check whether expert review has ever contradicted or qualified a favourable metric.
3. Confirm results are documented with the review.

EVIDENCE TO COLLECT

- Measurement results with expert review
- Instances where review qualified results

HOW TO DOCUMENT IT

Record whether domain expert review has ever qualified a favourable result, since a review that only confirms is not functioning as validation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: measurement results are not reviewed by domain experts, so favourable metrics are accepted without any check on whether they correspond to acceptable behaviour in practice.

MEASURE 4.3 Performance improvements or declines are identified from consultation and field data**WHAT THE SUBCATEGORY ASKS FOR**

Measurable performance improvements or declines, based on consultations with relevant AI actors including affected communities and on field data about context-relevant risks and trustworthiness characteristics, are identified and documented. Both directions of change must be tracked.

WHY IT EXISTS

The framework requires tracking declines, not only improvements, and organizations reliably track the former more diligently than the latter. Field data and community consultation are the sources most likely to reveal a decline, because they reflect the system as experienced rather than as measured.

HOW TO AUDIT IT

1. Verify both improvements and declines are identified and documented.
2. Check field data and community consultation inform the assessment.
3. Look for declines identified and what followed them.

EVIDENCE TO COLLECT

- Performance change tracking in both directions
- Field data and consultation input
- Records of identified declines and responses

HOW TO DOCUMENT IT

Record whether any decline has been identified and documented, since tracking that produces only improvements over an extended period is not measuring both directions.

EXECUTIVE SUMMARY TREATMENT

Suggested language: performance tracking has recorded improvements only across the period, with no decline identified despite field reports of degraded outcomes, so the measurement is not capturing deterioration.

MANAGE: Prioritization, Response, and Recovery

Thirteen subcategories covering what the organization does with what it has learned: the deployment decision, risk treatment, third-party management, and the operational apparatus that keeps a deployed system governed.

Mostly blue, with the monitoring and deactivation controls carrying technical weight. MANAGE 1.1 is the gate, and the two questions that reveal whether it functions are whether determinations cite the MAP and MEASURE findings, and whether any deployment has ever been declined. A process that has never said no has not demonstrated it can.

MANAGE 2.4 is the control of last resort and it fails on two dimensions at once: the technical ability to stop the system, and clarity about who may decide to. Test both, because a deactivation path first exercised during a crisis will not work. MANAGE 1.3 and 1.4 are where risk acceptance either becomes an accountable decision or happens by default: a high-priority risk with no documented response has been accepted by inaction, and residual risk documented only internally leaves downstream deployers and end users carrying exposure they cannot see.

Quick reference: MANAGE

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
MANAGE 1.1	A determination is made whether to proceed	Deployment determinations with rationale
MANAGE 1.2	Risk treatment is prioritized	Risk prioritization with impact and likelihood
MANAGE 1.3	Responses to high-priority risks are developed and documented	Risk responses per high-priority risk
MANAGE 1.4	Negative residual risks are documented	Residual risk documentation
MANAGE 2.1	Resources and non-AI alternatives are considered	Non-AI alternative analysis
MANAGE 2.2^{cyb}	Mechanisms sustain the value of deployed systems	Value sustainment mechanisms
MANAGE 2.3	Procedures respond to and recover from previously unknown risks	Response procedures for unknown risks
MANAGE 2.4^{cyb}	Mechanisms to supersede, disengage, or deactivate systems	Deactivation mechanisms per system
MANAGE 3.1^{cyb}	Third-party risks are monitored and controls applied	Third-party monitoring records
MANAGE 3.2^{cyb}	Pre-trained models are monitored as part of maintenance	Pre-trained model inventory with provenance
MANAGE 4.1^{cyb}	Post-deployment monitoring plans are implemented	Post-deployment monitoring plan
MANAGE 4.2	Continual improvement activities are integrated into updates	Improvement activities in update records

Ref	Title	Primary evidence
MANAGE 4.3	Incidents and errors are communicated and tracked	Incident and error tracking records

MANAGE 1.1 A determination is made whether to proceed**WHAT THE SUBCATEGORY ASKS FOR**

A determination is made as to whether the AI system achieves its intended purposes and stated objectives, and whether its development or deployment should proceed. This is the go or no-go decision, and the framework treats not proceeding as a real option.

WHY IT EXISTS

The entire MAP and MEASURE effort exists to inform this decision. A governance process that has never declined a deployment has not demonstrated that it can, and the value of the preceding work depends entirely on whether its findings can actually stop something.

HOW TO AUDIT IT

1. Verify a formal determination is made and recorded before deployment.
2. Check the determination references the MAP and MEASURE findings rather than proceeding independently of them.
3. Look for instances where a system did not proceed, or proceeded despite adverse findings.
4. Confirm the decision-maker had authority to decline.

EVIDENCE TO COLLECT

- Deployment determinations with rationale
- Linkage to MAP and MEASURE findings
- Records of declined or halted deployments

HOW TO DOCUMENT IT

Record whether any deployment has been declined or halted, and whether determinations reference the measurement findings. A determination that does not cite the findings was made independently of them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: deployment determinations do not reference the risk findings produced for the systems concerned, and no deployment has been declined, so the assessment process does not function as a gate.

MANAGE 1.2 Risk treatment is prioritized

WHAT THE SUBCATEGORY ASKS FOR

Treatment of documented AI risks is prioritized based on impact, likelihood, and available resources or methods. Prioritization must be explicit, since resources are finite.

WHY IT EXISTS

Without explicit prioritization, treatment follows tractability: the risks that are easy to fix get fixed, and the serious ones that are hard remain open. Prioritizing on impact and likelihood is what directs finite effort toward consequence rather than convenience.

HOW TO AUDIT IT

1. Verify risks are prioritized on impact and likelihood rather than on ease of remediation.
2. Compare the priority order against the treatment order actually followed.
3. Look for high-impact risks remaining open while lower-impact ones were addressed.

EVIDENCE TO COLLECT

- Risk prioritization with impact and likelihood
- Treatment sequence actually followed

HOW TO DOCUMENT IT

Compare stated priority against treatment order, since a mismatch shows prioritization is nominal and effort is following tractability instead.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risks rated highest impact remain untreated while lower-priority items have been closed, so remediation is following ease rather than the organization's own prioritization.

MANAGE 1.3 Responses to high-priority risks are developed and documented**WHAT THE SUBCATEGORY ASKS FOR**

Responses to the AI risks deemed high priority, as identified by the MAP function, are developed, planned, and documented. Response options include mitigating, transferring, avoiding, or accepting the risk.

WHY IT EXISTS

Naming the four options matters because acceptance is legitimate but must be a decision rather than a default. A high-priority risk with no documented response has been accepted by inaction, without anyone deciding to accept it or being accountable for having done so.

HOW TO AUDIT IT

1. Verify every high-priority risk has a documented response identifying which of the four options was chosen.
2. Check acceptances are explicit decisions by someone with authority, not defaults.
3. Confirm planned mitigations have owners and dates.
4. Look for high-priority risks with no response at all.

EVIDENCE TO COLLECT

- Risk responses per high-priority risk
- Acceptance decisions with decision-maker
- Mitigation plans with owners and dates

HOW TO DOCUMENT IT

Record high-priority risks with no documented response, since these have been accepted by default without any accountable decision.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of high-priority AI risks have no documented response, so they have been accepted by inaction rather than by a decision anyone is accountable for.

MANAGE 1.4 Negative residual risks are documented**WHAT THE SUBCATEGORY ASKS FOR**

Negative residual risks, defined as the sum of all unmitigated risks, to both downstream acquirers of AI systems and end users are documented. Residual risk must be documented for those downstream, not only internally.

WHY IT EXISTS

Residual risk that stays inside the developing organization leaves downstream acquirers and end users exposed to risks they cannot see and have not accepted. This subcategory is what makes those risks transferable knowledge rather than a hidden inheritance.

HOW TO AUDIT IT

1. Verify residual risk is documented as an aggregate, not only as individual open items.
2. Check residual risk is communicated to downstream acquirers and end users.
3. Confirm end users are informed of risks that affect them.

EVIDENCE TO COLLECT

- Residual risk documentation
- Communication to downstream acquirers
- End user disclosure

HOW TO DOCUMENT IT

Record whether residual risk reaches downstream acquirers and end users, since residual risk known only internally leaves those bearing it unaware of it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: residual risk is documented internally but not communicated to the business units deploying the system or to end users, so those bearing the risk are unaware of it.

MANAGE 2.1 Resources and non-AI alternatives are considered**WHAT THE SUBCATEGORY ASKS FOR**

Resources required to manage AI risks are taken into account, along with viable non-AI alternative systems, approaches, or methods, to reduce the magnitude or likelihood of potential impacts. The non-AI alternative must be genuinely considered.

WHY IT EXISTS

The most effective AI risk mitigation is sometimes not using AI for that task. Requiring consideration of non-AI alternatives forces the question of whether the risk is worth carrying at all, which is a question that rarely gets asked once a project has momentum.

HOW TO AUDIT IT

1. Verify non-AI alternatives were considered and the consideration is documented.
2. Check the comparison was genuine rather than a formality justifying a decision already made.
3. Confirm resources needed to manage the risks were assessed and are available.

EVIDENCE TO COLLECT

- Non-AI alternative analysis
- Resource requirements for risk management
- Comparison rationale

HOW TO DOCUMENT IT

Record whether non-AI alternatives were considered before or after the decision to build, since retrospective consideration is justification rather than analysis.

EXECUTIVE SUMMARY TREATMENT

Suggested language: non-AI alternatives were not considered before committing to an AI approach, so the organization has not established that the risks it now manages were necessary to accept.

MANAGE 2.2 Mechanisms sustain the value of deployed systems

WHAT THE SUBCATEGORY ASKS FOR

Mechanisms are in place and applied to sustain the value of deployed AI systems. Value is not self-sustaining; it degrades without maintenance.

WHY IT EXISTS

Deployed models degrade as their environment changes, and without deliberate maintenance a system that delivered value at launch delivers progressively less while carrying the same risks. Sustaining value requires retraining, revalidation, and adjustment as conditions change.

HOW TO AUDIT IT

1. Verify mechanisms exist to sustain value, including retraining and revalidation where applicable.
2. Check whether value has been reassessed since deployment.
3. Examine whether degraded systems are maintained, retired, or left running.

EVIDENCE TO COLLECT

- Value sustainment mechanisms
- Retraining and revalidation records
- Post-deployment value assessment

HOW TO DOCUMENT IT

Record whether deployed systems are maintained and revalidated, since systems left unmaintained carry undiminished risk against diminishing benefit.

EXECUTIVE SUMMARY TREATMENT

Suggested language: deployed systems are not retrained or revalidated after launch, so they carry their original risks against benefits that have degraded with the changing environment.

MANAGE 2.3 Procedures respond to and recover from previously unknown risks**WHAT THE SUBCATEGORY ASKS FOR**

Procedures are followed to respond to and recover from a previously unknown risk when it is identified. This is the response path for the risk nobody anticipated.

WHY IT EXISTS

The risks that cause the most damage are frequently the ones not on the register, and by definition no specific mitigation exists for them. What is needed is a general procedure for responding quickly when something unanticipated appears, since the alternative is improvisation during an incident.

HOW TO AUDIT IT

1. Verify procedures exist for responding to newly identified, previously unknown risks.
2. Check the procedure enables rapid response, including the ability to suspend a system.
3. Examine any actual instance of a previously unknown risk and how it was handled.

EVIDENCE TO COLLECT

- Response procedures for unknown risks
- Suspension and rollback capability
- Records of actual responses

HOW TO DOCUMENT IT

Record whether the procedure permits rapid suspension of a system, since the ability to stop quickly is the primary control against a risk nobody planned for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no procedure exists for responding to a newly discovered risk, and suspending a deployed system requires a change process taking weeks, so a serious emergent risk could not be contained promptly.

MANAGE 2.4 Mechanisms to supersede, disengage, or deactivate systems

WHAT THE SUBCATEGORY ASKS FOR

Mechanisms are in place and applied, and responsibilities are assigned and understood, to supersede, disengage, or deactivate AI systems that demonstrate performance or outcomes inconsistent with intended use. The off switch, with a named owner.

WHY IT EXISTS

This is the ultimate control, and it fails on two dimensions: the technical ability to stop the system, and the clarity about who may decide to do so. Both must exist, and both must have been tested, because a deactivation path first exercised during a crisis will not work.

HOW TO AUDIT IT

1. Verify a technical mechanism exists to deactivate or disengage each system.
2. Check responsibility for the decision is assigned and understood by the person holding it.
3. Test or verify the mechanism has been exercised, since untested shutdown paths commonly fail.
4. Examine dependent processes and what happens to them on deactivation.

EVIDENCE TO COLLECT

- Deactivation mechanisms per system
- Assigned deactivation authority
- Testing evidence for the mechanism
- Dependency analysis

HOW TO DOCUMENT IT

Record whether the deactivation path has been tested and whether the person with authority knows they hold it, since both are required and both are commonly absent.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no individual is identified as holding authority to deactivate the system and the technical deactivation path has never been tested, so the organization's ultimate control over the system is unverified.

MANAGE 3.1 Third-party risks are monitored and controls applied**WHAT THE SUBCATEGORY ASKS FOR**

AI risks and benefits from third-party resources are regularly monitored, and risk controls are applied and documented. Monitoring must be ongoing rather than performed at procurement.

WHY IT EXISTS

Third-party AI changes without notice: providers update models, alter behavior, and change terms. Risk assessed at procurement describes a system that may no longer exist. Regular monitoring is what keeps the assessment connected to what is actually running.

HOW TO AUDIT IT

1. Verify third-party AI resources are monitored on an ongoing basis, not only assessed at acquisition.
2. Check whether the organization would detect a provider changing a model.
3. Confirm controls are applied and documented per third-party resource.

EVIDENCE TO COLLECT

- Third-party monitoring records
- Provider change detection capability
- Applied controls per resource

HOW TO DOCUMENT IT

Record whether the organization can detect provider-side model changes, since an undetected change means the system in use differs from the system assessed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: third-party AI is assessed at procurement and never monitored thereafter, and provider model changes would not be detected, so the systems in use may differ materially from those assessed.

MANAGE 3.2 Pre-trained models are monitored as part of maintenance**WHAT THE SUBCATEGORY ASKS FOR**

Pre-trained models used for development are monitored as part of regular AI system monitoring and maintenance. Pre-trained models are called out specifically.

WHY IT EXISTS

Pre-trained models carry inherited properties the organization did not create and often cannot inspect: training data it cannot see, biases it did not introduce, and vulnerabilities it did not create. Because these are inherited rather than built, they are easily treated as somebody else's problem, which is why the framework names them separately.

HOW TO AUDIT IT

1. Identify pre-trained models in use and verify they are within the monitoring scope.
2. Check what the organization knows about each model's provenance and training data.
3. Confirm inherited risks are assessed rather than assumed to be the provider's responsibility.

EVIDENCE TO COLLECT

- Pre-trained model inventory with provenance
- Monitoring coverage for pre-trained components
- Inherited risk assessment

HOW TO DOCUMENT IT

Record what is known about each pre-trained model's provenance, since unknown provenance is an unquantified inheritance of bias, security, and intellectual property risk.

EXECUTIVE SUMMARY TREATMENT

Suggested language: pre-trained models are used without provenance information and are excluded from monitoring, so risks inherited from them are neither known nor tracked.

MANAGE 4.1 Post-deployment monitoring plans are implemented**WHAT THE SUBCATEGORY ASKS FOR**

Post-deployment AI system monitoring plans are implemented, including mechanisms for capturing and evaluating input from users and other relevant AI actors, appeal and override, decommissioning, incident response, recovery, and change management. This subcategory enumerates the operational apparatus.

WHY IT EXISTS

This is the checklist for whether an AI system is actually being operated rather than merely running. The named elements are each a common gap, and the requirement that the plan be implemented rather than written is the operative word: most organizations have the plan.

HOW TO AUDIT IT

1. Verify each named element exists: user input capture, appeal and override, decommissioning, incident response, recovery, and change management.
2. Check the plan is implemented rather than documented, testing at least two elements against actual practice.
3. Confirm appeal and override function as described.

EVIDENCE TO COLLECT

- Post-deployment monitoring plan
- Evidence of implementation per element
- Appeal and override operation records

HOW TO DOCUMENT IT

Test at least two named elements against actual practice rather than accepting the plan, and record which elements exist on paper only.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the post-deployment monitoring plan documents appeal, override, and incident response, but none of the three has been implemented operationally, so the plan describes controls that do not exist.

MANAGE 4.2 Continual improvement activities are integrated into updates**WHAT THE SUBCATEGORY ASKS FOR**

Measurable activities for continual improvement are integrated into AI system updates and include regular engagement with interested parties, including relevant AI actors. Improvement must be measurable and built into the update cycle.

WHY IT EXISTS

Improvement that is not integrated into the update process does not happen, because updates are driven by feature demand. Integrating measurable improvement activities is what ensures each update addresses known weaknesses rather than only adding capability.

HOW TO AUDIT IT

1. Verify improvement activities are integrated into the update cycle rather than tracked separately.
2. Check improvements are measurable and that measurement occurs.
3. Confirm engagement with interested parties informs the improvements.
4. Examine recent updates for improvement content alongside feature content.

EVIDENCE TO COLLECT

- Improvement activities in update records
- Measurement of improvement outcomes
- Stakeholder engagement informing improvements

HOW TO DOCUMENT IT

Examine recent updates and record the proportion addressing known weaknesses versus adding features, since improvement that never reaches the update cycle is not occurring.

EXECUTIVE SUMMARY TREATMENT

Suggested language: system updates across the period added functionality without addressing any identified weakness, so known issues persist while the system's capability and its risk surface both expand.

MANAGE 4.3 Incidents and errors are communicated and tracked**WHAT THE SUBCATEGORY ASKS FOR**

Incidents and errors are communicated to relevant AI actors, including affected communities. Processes for tracking, responding to, and recovering from incidents and errors are followed and documented. Communication extends to affected communities.

WHY IT EXISTS

The requirement to communicate to affected communities, not only internally, is what distinguishes this from ordinary incident management. People affected by an AI error frequently do not know it occurred, and cannot seek remedy for a harm they are unaware of.

HOW TO AUDIT IT

1. Verify incidents and errors are tracked and the process is followed.
2. Check communication reaches affected individuals and communities, not only internal stakeholders.
3. Examine actual incidents and whether those affected were informed.
4. Confirm recovery includes remedy for those harmed.

EVIDENCE TO COLLECT

- Incident and error tracking records
- Communication records including to affected parties
- Remedy and recovery evidence

HOW TO DOCUMENT IT

Record whether affected individuals were informed of incidents affecting them, since internal resolution without notification leaves people unaware of harms they might seek remedy for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: AI incidents affecting individuals were resolved internally without notifying those affected, so people subject to erroneous decisions remain unaware and cannot seek remedy.

CHAPTER 6

The Generative AI Profile: Twelve Risks

The twelve risks identified in NIST AI 600-1 as unique to, or exacerbated by, generative AI. This is a cross-cutting overlay rather than a fifth function: each risk connects back into the subcategories of GOVERN, MAP, MEASURE, and MANAGE, and the profile supplies suggested actions organized against them.

Applicability varies sharply. CBRN uplift is not a live concern for most deployments and is a defining one for a few, so the first assessment step is a documented applicability determination rather than uniform treatment. By contrast, confabulation, data privacy, human-AI configuration, and information security apply to essentially every generative deployment.

Three carry disproportionate practical weight. Confabulation is the risk most likely to cause routine harm, because the confidence of the output is unrelated to its correctness and defeats the heuristics people normally use to judge information. Information security centres on prompt injection, which has no complete solution: the assessment question is not whether injection can be prevented but what the system can reach if it succeeds, since permissions and tool access determine the blast radius. And human-AI configuration covers over-reliance, where an acceptance rate approaching total tells you users have stopped exercising the judgment the deployment assumes they provide.

Quick reference: GenAI Profile

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
GAI: CBRN_{cyb}	CBRN information or capabilities	Applicability determination with rationale
GAI: Confabulation_{cyb}	Confabulation	Confabulation rate measurement for the use case
GAI: Dangerous Content_{cyb}	Dangerous, violent, or hateful content	Content safeguard design and coverage
GAI: Data Privacy_{cyb}	Data privacy	Memorization and extraction testing
GAI: Environmental	Environmental impacts	Environmental impact assessment covering training and inference
GAI: Harmful Bias_{cyb}	Harmful bias or homogenization	Bias evaluation of generated content
GAI: Human-AI Configuration_{cyb}	Human-AI configuration	User interaction analysis
GAI: Information Integrity_{cyb}	Information integrity	Provenance or watermarking mechanisms
GAI: Information Security_{cyb}	Information security	Prompt injection assessment
GAI: Intellectual Property	Intellectual property	IP risk assessment

Ref	Title	Primary evidence
GAI: Obscene Content ^{CVB}	Obscene, degrading, and abusive content	Preventive safeguard design
GAI: Value Chain	Value chain and component integration	Value chain mapping per system

GAI: CBRN CBRN information or capabilities**WHAT THE SUBCATEGORY ASKS FOR**

The risk that a generative system lowers the barrier to entry for, or otherwise assists in, the design, development, or use of chemical, biological, radiological, or nuclear weapons. The concern is uplift: whether the system materially assists someone who could not otherwise obtain the capability, whether by synthesizing dispersed information or by supplying specialized reasoning.

WHY IT EXISTS

This is the highest-severity risk in the profile and the one where a single failure is catastrophic and irreversible. It is also distinctive in that the relevant question is not whether the information exists publicly but whether the system meaningfully accelerates access to it.

HOW TO AUDIT IT

1. Establish whether the system's capability and domain make this risk plausible, since it does not apply uniformly.
2. Verify safeguards exist against the model providing operational uplift, and check they were tested adversarially rather than assumed.
3. Confirm evaluation addressed uplift specifically, not only refusal of overt requests.
4. Check escalation routes exist for suspected misuse.

EVIDENCE TO COLLECT

- Applicability determination with rationale
- Safeguard design and adversarial testing results
- Uplift evaluation methodology

HOW TO DOCUMENT IT

Record whether the risk was assessed for applicability rather than dismissed, and whether testing addressed uplift rather than only refusal of explicit requests, since evasion of a refusal filter is straightforward.

EXECUTIVE SUMMARY TREATMENT

Suggested language: safeguards against CBRN-related misuse were tested only against explicit requests, with no adversarial testing of indirect routes, so the organization cannot demonstrate they resist determined circumvention.

GAI: Confabulation Confabulation

WHAT THE SUBCATEGORY ASKS FOR

The production of confidently stated content that is erroneous or fabricated. The profile uses confabulation rather than hallucination to emphasize that the system is not perceiving something absent but generating plausible content without regard to truth. Confidence of presentation is unrelated to correctness.

WHY IT EXISTS

Confabulation is the most pervasive generative AI risk and the hardest to control, because the mechanism producing useful output is the same one producing fabrication. Its danger comes from the mismatch between the confidence of presentation and the reliability of content, which defeats the heuristics people normally use to judge information.

HOW TO AUDIT IT

1. Verify confabulation rate has been measured for the actual use case rather than assumed low.
2. Check whether users are informed that output may be fabricated and whether that warning is effective.
3. Examine what verification is required before output is relied upon, and whether it actually occurs.
4. Look for uses where confabulation would be consequential and unverifiable by the user.

EVIDENCE TO COLLECT

- Confabulation rate measurement for the use case
- User warnings and their placement
- Verification requirements and compliance evidence

HOW TO DOCUMENT IT

Record the measured confabulation rate for the actual use case and whether verification is enforced or advisory, since advisory verification under time pressure is not performed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system's confabulation rate has never been measured for its actual use case, and verification of output is advisory rather than enforced, so fabricated content is likely reaching decisions unchecked.

GAI: Dangerous Content Dangerous, violent, or hateful content**WHAT THE SUBCATEGORY ASKS FOR**

The risk that the system produces content that is dangerous, violent, or hateful, including content inciting violence, promoting self-harm, or expressing hatred toward groups. This covers both content produced unprompted and content produced in response to adversarial prompting.

WHY IT EXISTS

Generative systems can produce such content both by accident and under deliberate elicitation, and the reputational, legal, and human consequences differ but are serious in both cases. The distinction matters for controls: filtering handles accidental production, while adversarial robustness is needed against deliberate elicitation.

HOW TO AUDIT IT

1. Verify content safeguards exist and check whether they were tested adversarially.
2. Distinguish protection against accidental production from protection against deliberate elicitation.
3. Examine what happens when safeguards fail, including detection and response.
4. Check safeguards cover the languages and contexts the system actually operates in.

EVIDENCE TO COLLECT

- Content safeguard design and coverage
- Adversarial testing results
- Failure detection and response

HOW TO DOCUMENT IT

Record whether safeguards were tested adversarially and whether coverage extends to all languages and contexts in use, since filters commonly perform far worse outside their primary language.

EXECUTIVE SUMMARY TREATMENT

Suggested language: content safeguards were tested only in English while the system operates in several languages, so protection is materially weaker for a substantial proportion of its actual use.

GAI: Data Privacy Data privacy**WHAT THE SUBCATEGORY ASKS FOR**

Risks to privacy arising from generative systems, including leakage or memorization of personal information from training data, inference of sensitive attributes, and disclosure of information entered by users into prompts. Each is a distinct mechanism requiring distinct controls.

WHY IT EXISTS

Generative systems create privacy risks that conventional data protection does not address. A model may reproduce training data verbatim, infer attributes never provided, or expose one user's prompt content to another. The prompt disclosure route is particularly common, since users enter sensitive information into systems they treat as private.

HOW TO AUDIT IT

1. Verify testing for memorization and training data extraction was performed.
2. Check what happens to user prompt content: retention, use for training, and exposure risk.
3. Examine whether users are informed how their inputs are handled.
4. Confirm attribute inference risk was assessed.

EVIDENCE TO COLLECT

- Memorization and extraction testing
- Prompt data handling and retention policy
- User disclosure about input handling

HOW TO DOCUMENT IT

Record how user prompt content is handled and whether users are informed, since staff routinely enter sensitive information into generative tools believing it is not retained.

EXECUTIVE SUMMARY TREATMENT

Suggested language: user prompt content is retained and used for model improvement without disclosure to users, and staff have entered sensitive information into the system on the assumption it was not retained.

GAI: Environmental Environmental impacts**WHAT THE SUBCATEGORY ASKS FOR**

The environmental cost of training and operating generative systems, including energy consumption, associated carbon emissions, and water use for cooling. Generative models carry substantially higher costs than conventional systems, at both training and inference.

WHY IT EXISTS

The costs are material and quantifiable, and unlike most risks in the profile they are certain rather than probabilistic. Inference cost is the element most often overlooked: a widely used generative feature can exceed its training cost over the deployment lifetime.

HOW TO AUDIT IT

1. Verify environmental impact was assessed for both training and inference.
2. Check inference costs at actual usage volumes are included.
3. Confirm the assessment covers third-party model use, where the cost is incurred by the provider.

EVIDENCE TO COLLECT

- Environmental impact assessment covering training and inference
- Usage volume data
- Third-party model usage accounting

HOW TO DOCUMENT IT

Record whether inference at actual volumes was counted, since ongoing inference frequently exceeds training cost and is routinely omitted.

EXECUTIVE SUMMARY TREATMENT

Suggested language: environmental assessment counted model training only, omitting inference at deployed volumes, which represents the larger share of the system's actual environmental cost.

GAI: Harmful Bias Harmful bias or homogenization**WHAT THE SUBCATEGORY ASKS FOR**

The risk that generative systems amplify harmful bias, and the distinct risk of homogenization: that widespread use of similar models narrows the diversity of content, ideas, and outputs across a domain. Homogenization is a societal-scale effect that no single deployment produces alone.

WHY IT EXISTS

Bias in generative output is both a direct harm and a compounding one, since generated content becomes training data for subsequent models. Homogenization is the harder risk because it is invisible from inside any individual deployment: each use looks reasonable while the aggregate effect narrows what gets produced.

HOW TO AUDIT IT

1. Verify bias evaluation covers generated content, including representational bias in depictions and descriptions.
2. Check evaluation covers the range of prompts and contexts encountered in practice.
3. Examine whether homogenization effects were considered at all.
4. Confirm bias evaluation is repeated as the model and its use change.

EVIDENCE TO COLLECT

- Bias evaluation of generated content
- Prompt and context coverage
- Homogenization consideration

HOW TO DOCUMENT IT

Record whether bias evaluation covers generated content across realistic prompt distributions, since evaluation on a narrow prompt set will miss bias that appears in ordinary use.

EXECUTIVE SUMMARY TREATMENT

Suggested language: bias evaluation of generated content used a narrow curated prompt set unrepresentative of actual use, so bias appearing in ordinary operation has not been assessed.

GAI: Human-AI Configuration Human-AI configuration

WHAT THE SUBCATEGORY ASKS FOR

Risks arising from how people interact with generative systems, including over-reliance, automation bias, anthropomorphization, emotional attachment, and misapprehension of the system's nature and reliability. This covers the human side of the interaction rather than the system's outputs.

WHY IT EXISTS

Generative systems invite anthropomorphization more strongly than any prior technology because they communicate fluently in natural language. Fluency is read as competence, which produces over-reliance, and users routinely form beliefs about the system's understanding that its architecture does not support.

HOW TO AUDIT IT

1. Examine how users actually interact with the system and whether over-reliance is present.
2. Check whether users understand what the system is and what its outputs represent.
3. Verify the interface design does not encourage unwarranted trust.
4. Look for decisions made on system output without the intended human judgment.

EVIDENCE TO COLLECT

- User interaction analysis
- User understanding evidence
- Interface design review for trust cues

HOW TO DOCUMENT IT

Record evidence of over-reliance, such as acceptance rates of system suggestions approaching total, since this indicates users have stopped exercising the judgment the design assumes.

EXECUTIVE SUMMARY TREATMENT

Suggested language: users accept the system's suggestions in nearly all cases and describe it in terms implying understanding it does not possess, so the independent human judgment the deployment assumes is not being exercised.

GAI: Information Integrity Information integrity**WHAT THE SUBCATEGORY ASKS FOR**

The risk that generative systems degrade the information ecosystem by enabling production of synthetic content at scale, including disinformation, impersonation, and material that is difficult to distinguish from authentic content. The risk is both to individual recipients and to collective trust in information.

WHY IT EXISTS

Generative systems reduce the cost of producing convincing false content to near zero, changing the economics of disinformation. The second-order effect matters as much as the first: as synthetic content becomes prevalent, authentic content becomes harder to trust, which erodes the shared basis for verification.

HOW TO AUDIT IT

1. Verify whether output is identifiable as AI-generated, through provenance mechanisms, watermarking, or disclosure.
2. Check whether the system could be used to produce content impersonating real people or institutions.
3. Examine controls against generation at scale.
4. Confirm disclosure to recipients of generated content where the organization distributes it.

EVIDENCE TO COLLECT

- Provenance or watermarking mechanisms
- Impersonation controls
- Disclosure practice for generated content

HOW TO DOCUMENT IT

Record whether generated content is identifiable as such by its recipients, since undisclosed synthetic content is the mechanism through which the risk is realized.

EXECUTIVE SUMMARY TREATMENT

Suggested language: content generated by the system is distributed without any indication of its synthetic origin and carries no provenance marking, so recipients cannot distinguish it from human-authored material.

GAI: Information Security Information security**WHAT THE SUBCATEGORY ASKS FOR**

Security risks specific to generative systems, including prompt injection, jailbreaking, extraction of system instructions or training data, and the use of generative capability to assist offensive operations such as producing malicious code or phishing content.

WHY IT EXISTS

Prompt injection is the distinctive vulnerability class, and it has no complete solution: because instructions and data share a channel, content the system processes can carry instructions it follows. Any generative system processing untrusted input is exposed, and the exposure grows as systems are given tools and autonomy.

HOW TO AUDIT IT

1. Verify prompt injection risk was assessed, particularly where the system processes untrusted content.
2. Check what the system can do if instructions are successfully injected, since impact depends on its permissions and tools.
3. Examine jailbreak resistance and whether testing was adversarial.
4. Confirm system instructions and connected data are protected from extraction.

EVIDENCE TO COLLECT

- Prompt injection assessment
- System permissions and tool access inventory
- Adversarial testing results

HOW TO DOCUMENT IT

Record what the system can do and reach if injection succeeds, since the permissions and tools available to it determine the blast radius far more than the strength of the input filtering.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the system processes untrusted external content while holding access to internal data and tools, and prompt injection resistance has not been tested, so a successful injection could reach systems well beyond the generative component.

GAI: Intellectual Property Intellectual property

WHAT THE SUBCATEGORY ASKS FOR

Risks that generative systems reproduce or closely imitate copyrighted, trademarked, or otherwise protected material, whether through memorization of training data or through generation of substantially similar content. The exposure attaches to the user of the output as well as the developer.

WHY IT EXISTS

This is a live and unsettled legal area, and the exposure transfers: an organization using generated content commercially may face liability regardless of who trained the model. Because the organization typically cannot inspect the training data of a third-party model, it is accepting an unquantified risk.

HOW TO AUDIT IT

1. Verify intellectual property risk was assessed for the models in use.
2. Check what is known about training data provenance and licensing.
3. Examine the terms governing output ownership and indemnification from the provider.
4. Confirm controls exist where output is used commercially or published.

EVIDENCE TO COLLECT

- IP risk assessment
- Training data provenance information
- Provider terms including indemnification

HOW TO DOCUMENT IT

Record the provider's indemnification position and what is known about training data, since these determine where the exposure actually lands.

EXECUTIVE SUMMARY TREATMENT

Suggested language: generated content is used commercially with no analysis of intellectual property exposure, unknown training data provenance, and no indemnification from the provider, so the organization bears an unquantified liability.

GAI: Obscene Content Obscene, degrading, and abusive content**WHAT THE SUBCATEGORY ASKS FOR**

The risk that generative systems produce obscene, degrading, or abusive content, including non-consensual intimate imagery and child sexual abuse material. The profile treats material involving minors as categorically distinct given its severity and unambiguous illegality.

WHY IT EXISTS

This category includes the most severe illegal content risks, and the consequences are criminal rather than merely reputational. Controls must be preventive rather than detective, since content of this kind causes harm on production and cannot be remedied after the fact.

HOW TO AUDIT IT

1. Verify preventive safeguards exist, and confirm they are preventive rather than only detective.
2. Check safeguards were tested against adversarial and indirect elicitation.
3. Confirm reporting obligations are understood and routes exist.
4. Examine controls on image and multimodal generation specifically where applicable.

EVIDENCE TO COLLECT

- Preventive safeguard design
- Adversarial testing results
- Reporting obligation procedures

HOW TO DOCUMENT IT

Record whether safeguards prevent rather than detect, and whether legal reporting obligations are understood by those operating the system.

EXECUTIVE SUMMARY TREATMENT

Suggested language: safeguards against illegal content operate by post-generation detection rather than prevention, and staff are unaware of applicable reporting obligations, so prohibited material could be generated and the required reports not made.

GAI: Value Chain Value chain and component integration**WHAT THE SUBCATEGORY ASKS FOR**

Risks arising from the generative AI value chain: dependence on third-party foundation models, data, and components whose properties the organization cannot inspect, and the opacity that results from building on layers each provided by a different party.

WHY IT EXISTS

Most organizations deploying generative AI are several layers removed from the model's creation, with limited visibility into training data, evaluation, or changes. Risk assessment of a system built on components nobody can inspect rests substantially on assertions, and every layer adds distance between the organization and what it is actually accountable for.

HOW TO AUDIT IT

1. Map the value chain for each generative system: who built the model, who hosts it, what sits between.
2. Check what the organization knows about each layer versus what it assumes.
3. Verify contractual protections and disclosure obligations at each layer.
4. Confirm the organization would learn of a change made upstream.

EVIDENCE TO COLLECT

- Value chain mapping per system
- Known versus assumed properties at each layer
- Contractual and disclosure terms

HOW TO DOCUMENT IT

Record what is known versus assumed at each layer of the value chain, since the accumulated assumptions are what the organization's risk assessment actually rests on.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the generative systems in use depend on foundation models several layers removed from the organization, with no visibility into training data, evaluation, or upstream changes, so the risk assessment rests on assertions the organization cannot verify.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

AI actor

Any organization or individual playing a role across the AI lifecycle, including those who design, develop, deploy, operate, evaluate, or use AI systems. The framework uses the term deliberately broadly, because risk decisions are distributed across many parties rather than held by one.

AI RMF Core

The four functions – GOVERN, MAP, MEASURE, MANAGE – and their categories and subcategories. Seventy-two subcategories in total.

Automation bias

The human tendency to over-trust automated output and to under-weight contradicting evidence. The principal reason human oversight fails as a control: the overseer defers to the system rather than checking it.

Confabulation

The production of confidently stated content that is erroneous or fabricated. The Generative AI Profile prefers this term over hallucination, to emphasise that the system generates plausible content without regard to truth rather than perceiving something absent.

Construct validity

Whether the thing being measured is actually the thing of interest. A model predicting re-arrest is not predicting reoffending. When the construct is wrong, downstream accuracy testing measures the wrong thing precisely.

Emergent risk

A risk that appears through the operation of the system rather than being identified beforehand, arising from interaction between the system, its users, and a changing environment.

Explainability

A representation of the mechanisms underlying a system's operation: how it works. Distinct from interpretability.

Generative AI Profile

NIST AI 600-1, a cross-sectoral profile identifying twelve risks unique to or exacerbated by generative AI, with suggested actions mapped against the AI RMF subcategories.

GOVERN

The cross-cutting function establishing culture, accountability, policy, and oversight. Applies throughout the lifecycle rather than at a particular stage.

Homogenization

The narrowing of diversity in content, ideas, and outputs that can result from widespread use of similar generative models. A societal-scale effect invisible from within any single deployment.

Interpretability

The meaning of a system's output in the context of its designed functional purpose: what the output means for the person receiving it. Distinct from explainability, and both are needed.

MANAGE

The function covering prioritisation of risks, response, third-party management, and the operational apparatus that keeps a deployed system governed.

MAP

The function establishing context, categorising the system, and characterising impacts. Produces the inputs that MEASURE evaluates.

MEASURE

The function covering analysis, testing, evaluation, and tracking. The empirical core of the framework.

Profile

An implementation of the AI RMF functions tailored to a specific sector, technology, or use case. The Generative AI Profile is a cross-sectoral example.

Prompt injection

An attack in which content processed by a generative system carries instructions the system follows. Has no complete solution, because instructions and data share a channel. The relevant question is what the system can reach if injection succeeds.

Residual risk

The sum of all unmitigated risks. The framework requires it be documented for downstream acquirers and end users, not only internally.

Risk tolerance

The level of risk the organization is willing to accept, stated specifically enough to guide a decision. Without it, risk acceptance rests on individual judgment.

Subcategory

The most granular level of the AI RMF Core, expressed as an outcome. There are 72 across the four functions, and they are what this guide describes one at a time.

TEVV

Test, evaluation, verification, and validation. The activities through which the MEASURE function is performed.

Trustworthy AI characteristics

The seven properties the framework identifies: valid and reliable; safe; secure and resilient; accountable and transparent; explainable and interpretable; privacy-enhanced; and fair with harmful bias managed.

Uplift

In the CBRN context, whether a system materially assists someone in obtaining a capability they could not otherwise achieve. The relevant question is acceleration of access, not whether the underlying information exists publicly.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded. Written so a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- A determination is made whether to proceed, 76
- Accountable and Transparent: information is available and responsibility is assigned, 5
- Adjudicated feedback is incorporated into design and implementation, 27
- AI actor, 103
- AI RMF Core, 103
- An AI system inventory exists and is resourced, 16
- Approaches for mapping technology and legal risks of components are in place, 46
- Approaches to track existing, unanticipated, and emergent risks, 68
- Automation bias, 103
- Business value or context of use is defined or re-evaluated, 35
- CBRN information or capabilities, 91
- Confabulation, 92, 103
- Construct validity, 103
- Contingency processes exist for third-party failures, 29
- Continual improvement activities are integrated into updates, 87
- Dangerous, violent, or hateful content, 93
- Data privacy, 94
- Decision-making is informed by a diverse team, 21
- Decommissioning processes exist and are safe, 17
- Effectiveness of TEVV metrics and processes is evaluated, 67
- Emergent risk, 103
- Environmental impact and sustainability are assessed, 66
- Environmental impacts, 95
- Executive leadership takes responsibility for AI risk decisions, 20
- Explainability, 103
- Explainable and Interpretable: the mechanism and the meaning are both available, 6
- External feedback on impacts is collected and integrated, 26
- Fair – with Harmful Bias Managed: equality and equity, with bias addressed, 8
- Fairness and bias are evaluated and results documented, 65
- Feedback and appeal processes for end users and impacted communities, 70
- Functionality and behavior are monitored in production, 58
- Generative AI Profile, 103
- GOVERN, 103
- Harmful bias or homogenization, 96
- Homogenization, 103
- Human oversight processes are defined and assessed, 45
- Human subject evaluations meet requirements and are representative, 56
- Human-AI configuration, 97
- Human-AI configuration roles are defined and differentiated, 22
- Incidents and errors are communicated and tracked, 88
- Independent assessors and external consultation are involved, 54
- Information integrity, 98
- Information security, 99
- Intellectual property, 100
- Intended purpose, context, laws, norms, and settings are documented, 32
- Interdisciplinary AI actors and diversity of expertise are documented, 33
- Internal risk controls for components are identified, 47
- Interpretability, 104

- Knowledge limits and human oversight of output are documented, [39](#)
- Legal and regulatory requirements are understood and managed, [11](#)
- Likelihood and magnitude of impacts are identified, [48](#)
- MANAGE, [104](#)
- MAP, [104](#)
- MEASURE, [104](#)
- Measurement approaches are connected to deployment context, [71](#)
- Measurement results are validated by domain experts and AI actors, [72](#)
- Mechanisms sustain the value of deployed systems, [81](#)
- Mechanisms to supersede, disengage, or deactivate systems, [83](#)
- Metric appropriateness and control effectiveness are reassessed, [53](#)
- Metrics are selected, and the unmeasurable is documented, [52](#)
- Monitoring and periodic review are planned with defined roles, [15](#)
- Negative residual risks are documented, [79](#)
- Obscene, degrading, and abusive content, [101](#)
- Operator and practitioner proficiency processes are defined, [44](#)
- Organizational mission and goals for the technology are documented, [34](#)
- Organizational risk tolerances are determined and documented, [36](#)
- Performance improvements or declines are identified from consultation and field data, [73](#)
- Performance is measured for deployment-like conditions, [57](#)
- Personnel and partners receive AI risk management training, [19](#)
- Policies foster critical thinking and a safety-first mindset, [23](#)
- Post-deployment monitoring plans are implemented, [86](#)
- Potential benefits are examined and documented, [41](#)
- Potential costs including non-monetary costs are examined, [42](#)
- Practices and personnel support engagement and feedback integration, [49](#)
- Practices enable testing, incident identification, and information sharing, [25](#)
- Pre-trained models are monitored as part of maintenance, [85](#)
- Privacy risk is examined and documented, [64](#)
- Privacy-Enhanced: norms of autonomy, identity, and dignity are safeguarded, [7](#)
- Procedures respond to and recover from previously unknown risks, [82](#)
- Profile, [104](#)
- Prompt injection, [104](#)
- Residual risk, [104](#)
- Resources and non-AI alternatives are considered, [80](#)
- Responses to high-priority risks are developed and documented, [78](#)
- Risk management activity is scaled to risk tolerance, [13](#)
- Risk tolerance, [104](#)
- Risk tracking where measurement is difficult or unavailable, [69](#)
- Risk treatment is prioritized, [77](#)
- Roles, responsibilities, and communication lines are documented, [18](#)
- Safe: the system does not endanger life, health, property, or environment, [3](#)
- Safety risks are evaluated regularly and safe failure is demonstrated, [60](#)
- Scientific integrity and TEVV considerations are documented, [40](#)
- Secure and Resilient: the system withstands adversarial and adverse events, [4](#)
- Security and resilience are evaluated and documented, [61](#)
- Subcategory, [104](#)
- System requirements are elicited from and understood by AI actors, [37](#)
- Targeted application scope is specified, [43](#)
- Tasks and implementation methods are defined, [38](#)
- Teams document and communicate risks and potential impacts, [24](#)

Test sets, metrics, and TEVV tooling are documented, [55](#)
TEVV, [104](#)
The model is explained, validated, and outputs interpreted in context, [63](#)
The risk management process is established transparently, [14](#)
Third-party AI risks are addressed by policy, including IP, [28](#)
Third-party risks are monitored and controls applied, [84](#)
Transparency and accountability risks are examined, [62](#)

Trustworthy AI characteristics, [104](#)
Trustworthy AI characteristics are integrated into policy, [12](#)
Uplift, [104](#)
Valid and Reliable: the system does what it claims, consistently, [2](#)
Validity and reliability are demonstrated, with generalizability limits, [59](#)
Value chain and component integration, [102](#)
Workpaper, [104](#)